

Um processo de gestão de ativos rastreia todos os sistemas, componentes, dispositivos e outros objetos de valor críticos da organização em um inventário. Isso também envolve a coleta e análise de informações sobre esses ativos, para que a equipe possa fazer alterações conscientes ou trabalhar com os ativos para atingir as metas de negócios.

Existem muitos pacotes de software e soluções de hardware associadas disponíveis para rastrear e gerenciar ativos. Um banco de dados de gestão de ativos pode armazenar a quantidade de informações necessárias para atender às demandas específicas. Os dados mais comuns são tipo, modelo, número de série, ID do ativo, localização, usuário(s), valor e informações de serviço.

Nota:

Estamos focando os ativos técnicos que exigem algum grau de configuração. Uma organização também tem muitos ativos sem requisitos de configuração, como móveis e edifícios.

Atribuição de ativos/contabilização e monitoramento/rastreamento de ativos

A [[atribuição - contabilização]] de propriedade de ativos e a classificação são componentes essenciais de um processo de gerenciamento de ativos bem estruturado, garantindo que as organizações gerenciem e protejam seus recursos de forma eficaz, ao mesmo tempo em que mantêm a accountability.

Atribuir a propriedade de ativos envolve designar equipes ou indivíduos específicos dentro da organização como responsáveis por ativos específicos para estabelecer uma cadeia clara de responsabilidade pela segurança, manutenção e gerenciamento contínuo de ativos. A classificação de ativos envolve a organização dos ativos com base em seu valor, confidencialidade ou importância para a organização. Isso permite a aplicação consistente e reiterada dos controles de segurança necessários, a priorização eficaz para manutenção e atualizações, bem como a alocação de orçamento apropriado. Ambos os processos precisam de revisões periódicas para levar em conta as mudanças no valor, confidencialidade ou relevância do ativo para as operações de negócios.

As [[atividades de monitoramento - rastreamento]] de ativos incluem tarefas de inventário e enumeração, que envolvem a criação e manutenção de uma lista abrangente de todos os ativos da organização, como hardware, software, dados e equipamentos de rede. Atualizar e verificar regularmente o inventário de ativos ajuda as organizações a identificar e gerenciar seus ativos de forma eficaz, o que garante que elas tenham informações precisas sobre a localização, o proprietário e o status de cada ativo. Estas informações são vitais para o gerenciamento de licenças, implantação de patches e resposta a incidentes de segurança. O monitoramento de ativos também envolve o rastreamento de desempenho, segurança e uso de ativos, permitindo que as organizações detectem rapidamente possíveis problemas, vulnerabilidades ou acesso não autorizado. O monitoramento proativo de ativos ajuda a reduzir riscos, otimizar a utilização de recursos e garantir a conformidade com os requisitos regulatórios.

Há várias maneiras de realizar a enumeração de ativos, dependendo do tamanho e da complexidade da organização e dos tipos de ativos envolvidos:

- **Inventário manual:** em organizações menores ou para tipos de ativos específicos, a criação e manutenção manual de um inventário de ativos pode ser viável. Este processo envolve a inspeção física de ativos, como

computadores, servidores e dispositivos de rede, e o registro das informações relevantes, como números de série, marca, modelo e localização.

- **Varredura de rede:** ferramentas de varredura de rede, como Nmap, Nessus ou OpenVAS, conseguem detectar e enumerar automaticamente dispositivos em rede, incluindo servidores, switches, roteadores e estações de trabalho. Estas ferramentas conseguem identificar portas abertas, serviços e, às vezes, até mesmo os sistemas operacionais e aplicativos em execução nos dispositivos.
- **Software de gerenciamento de ativos:** Soluções de software para gerenciamento de ativos, como Lansweeper, ManageEngine ou SolarWinds, podem descobrir, rastrear e catalogar automaticamente vários tipos de ativos, incluindo hardware, software e licenças. Essas ferramentas geralmente fornecem um painel centralizado para gerenciar o inventário de ativos, monitorar alterações e gerar relatórios.
- **Banco de Dados de Gerenciamento de Configuração (CMDB):** Um CMDB é um repositório centralizado de informações relacionadas à infraestrutura de TI de uma organização, incluindo ativos, configurações e relacionamentos. Ferramentas como ServiceNow ou BMC Remedy podem ajudar a criar e manter um CMDB, fornecendo uma visão holística dos ativos e interdependências da organização.
- **Soluções de Gerenciamento de Dispositivos Móveis (MDM):** Para organizações com um número significativo de dispositivos móveis, soluções de MDM como Microsoft Intune, VMware Workspace ONE ou MobileIron podem ajudar a enumerar, gerenciar e proteger smartphones, tablets e outros ativos móveis.
- **Descoberta de ativos em nuvem:** com a crescente adoção dos serviços em nuvem pelas organizações, ferramentas nativas em nuvem, como o AWS Config e o Azure Resource Graph, ou soluções de terceiros, como o CloudAware e o CloudCheckr, podem ajudar a descobrir e catalogar ativos implantados na nuvem.

Aquisição/obtenção de ativos

Do ponto de vista do suporte às operações de cibersegurança, as políticas de [[aquisição - preocupantemente]] ativos são fundamentais para garantir que as organizações mantenham uma postura de segurança robusta. As principais considerações incluem a seleção de soluções de hardware e software com fortes recursos de segurança, como criptografia integrada, mecanismos de inicialização segura e atualizações ou correções regulares. É fundamental trabalhar com fornecedores e fabricantes respeitáveis que priorizem a segurança e forneçam suporte contínuo para lidar com possíveis vulnerabilidades em seus produtos.

Além disso, as organizações devem procurar adquirir soluções que se integrem perfeitamente à sua infraestrutura de segurança (firewalls, sistemas de detecção de intrusão ou plataformas de gerenciamento de informações e eventos de segurança [SIEM]). Isso facilita uma estratégia de segurança mais coesa e eficaz.

Além disso, as organizações devem avaliar o custo total de propriedade (TCO) dos ativos, considerando o preço inicial de compra, juntamente com os custos contínuos de manutenção, atualizações e possíveis incidentes de segurança.

Priorizar a segurança cibernética durante o processo de aquisição e obtenção de ativos ajuda as organizações a construir uma base sólida para suas operações de segurança, o que reduz o risco de violações, aprimora a conformidade com os regulamentos relevantes e, por fim, protege seus dados e sistemas críticos.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Do ponto de vista das operações de segurança cibernética, os ativos consistem em recursos, informações e componentes de infraestrutura críticos, que devem ser protegidos contra ameaças em potencial e acesso não autorizado. O termo “ativo” engloba recursos como dispositivos de hardware, aplicativos de software, repositórios de dados, componentes de rede e outros. A proteção de ativos é fundamental para manter a integridade, confidencialidade e disponibilidade do sistema de informações de uma organização.

As equipes de segurança cibernética são responsáveis por identificar e priorizar esses ativos baseados na sua confidencialidade e no possível impacto nas funções principais da organização caso sejam perdidos, roubados ou violados. A proteção ativa deles minimiza os possíveis impactos das violações de segurança e reduz a probabilidade de perdas ou danos.

Convenções de nomenclatura padrão e identificação de ativos

Os ativos tangíveis podem ser identificados com uma etiqueta de código de barras ou etiqueta de identificação por radiofrequência (RFID) anexada ao dispositivo (ou simplesmente com um número de identificação). Uma etiqueta RFID é um chip programado com dados do ativo. Quando está ao alcance de um scanner, o chip é ativado e envia um sinal ao scanner. O scanner alerta o software de gerenciamento para atualizar a localização do dispositivo. Além de rastrear o ativo, isto permite que o software de gerenciamento localize o dispositivo, dificultando o roubo.

Uma [[convenção de nomenclatura]] padrão torna o ambiente mais consistente tanto para ativos de hardware quanto para ativos digitais, como contas e máquinas virtuais. A estratégia de nomenclatura deve permitir que os administradores identifiquem o tipo e a função de recursos ou locais específicos em qualquer ponto do banco de dados de gerenciamento de configurações (CMDB) ou do diretório de rede. Cada etiqueta deve estar em conformidade com as regras para nomes de host e DNS (<https://support.microsoft.com/pt-br/help/909264/naming-conventions-in-active-directory-for-computers-domains-sites-and> (<https://support.microsoft.com/en-us/help/909264/naming-conventions-in-active-directory-for-computers-domains-sites-and>)). Além de um atributo de identificação, a localização e a função dos ativos tangíveis e digitais podem ser registradas usando tags e campos de atributos ou registros de recursos DNS CNAME e TXT.

O [gerenciamento de configuração](#) garante que cada elemento configurável dentro do inventário de ativos não tenha divergido de sua configuração aprovada. [O controle e o gerenciamento](#) de [mudanças reduzem](#) o risco de que alterações nesses componentes possam causar interrupção nas operações da organização.

ITIL® é uma popular estrutura de documentação de atividades e processos de boas e melhores práticas para a prestação de serviços de TI. No ITIL, o gerenciamento de configuração é implementado usando os seguintes elementos:

- Ativos de serviço são coisas, processos ou pessoas que contribuem para a prestação de um serviço de TI.
- Um item de configuração (CI) é um ativo que requer procedimentos de gerenciamento específicos para serem usados na entrega do serviço. Cada CI deve ter uma etiqueta, idealmente usando uma convenção de nomenclatura padrão. Os CIs são definidos por seus atributos e relacionamentos armazenados em um banco de dados de gerenciamento de configurações (CMDB).
- Uma configuração padrão é uma lista de configurações às quais um ativo, como um servidor ou aplicativo, deve aderir. As linhas de base de segurança descrevem o conjunto mínimo de definições de configuração de segurança que um dispositivo ou software deve manter para ser considerado adequadamente protegido.
- Um sistema de gerenciamento de configurações (CMS) descreve as ferramentas e bancos de dados usados para coletar, armazenar, gerenciar, atualizar e relatar informações sobre CIs. Uma pequena rede pode registrar essas informações em planilhas e diagramas, enquanto uma organização de grande porte pode investir em aplicativos dedicados, projetados para ambientes corporativos.

Diagrams (Diagramas) são a melhor maneira de representar relações complexas entre elementos de rede. Os diagramas demonstram o uso de CIs em fluxos de trabalho de negócios, topologias de rede lógica (IP) e física e layouts de rack de rede.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os [backups](#) desempenham um papel essencial na proteção de ativos, garantindo a disponibilidade e a integridade dos dados e sistemas críticos de uma organização. Ao criar cópias de informações importantes e armazená-las com segurança em locais separados, os backups constituem uma rede de segurança em caso de falha do hardware, corrupção de dados ou ataques cibernéticos, como ransomware. Testar e verificar regularmente os dados de backup é fundamental para garantir a confiabilidade do processo de recuperação.

Em um ambiente corporativo, técnicas simples de backup geralmente se mostram insuficientes para lidar com as necessidades e desafios exclusivos das grandes organizações. A escalabilidade se torna uma preocupação crítica quando grandes quantidades de dados precisam ser gerenciadas com eficiência. Os métodos simples de backup podem ter dificuldades para acomodar o crescimento do tamanho e da complexidade dos dados.

Os problemas de desempenho causados por técnicas simples de backup podem atrapalhar as operações de negócios porque tornam os aplicativos mais lentos durante a execução e geralmente têm tempos longos de recuperação. Além disso, as grandes empresas exigem maior detalhamento e personalização para lidar com aplicativos, bancos de dados ou subconjuntos de dados específicos, que técnicas simples muitas vezes não conseguem fornecer.

Os requisitos de conformidade e segurança exigem recursos avançados (p. ex., criptografia de dados, controle de acesso e trilhas de auditoria), que as abordagens simplistas normalmente não possuem. Além disso, planos robustos de recuperação de desastres e gerenciamento centralizado são componentes essenciais de uma estratégia de backup corporativo. As técnicas simples de backup em alguns casos não são compatíveis com recursos avançados, como replicação fora do local, failover automatizado ou gerenciamento simplificado dos diversos sistemas e locais geográficos que compõem o ambiente de tecnologia da informação de uma organização moderna.

Os recursos críticos para soluções de backup corporativo geralmente incluem o seguinte:

- Suporte para diversos ambientes (virtual, físico e nuvem)
- Desduplicação de dados e compactação para otimizar o espaço de armazenamento
- Recuperação instantânea e replicação para failover rápido
- Proteção contra ransomware e criptografia para segurança de dados
- Opções de restauração detalhada para arquivos individuais, pastas ou aplicativos
- Ferramentas de relatório, monitoramento e alerta para uma gestão eficaz
- Integração com plataformas de virtualização populares, provedores de nuvem e sistemas de armazenamento

A desduplicação de dados consiste em uma técnica de compactação de dados que otimiza o espaço de armazenamento ao identificar e eliminar dados redundantes. Ela funciona analisando blocos de dados dentro de um conjunto de dados e comparando-os para encontrar blocos idênticos. Em vez de armazenar várias cópias dos mesmos dados, a desduplicação armazena uma única cópia e cria referências ou sinalizadores para essa cópia em todas as outras instâncias. A desduplicação pode ser realizada em diferentes âmbitos, como arquivo, bloco ou byte. A desduplicação reduz consideravelmente os requisitos de armazenamento e melhora a eficiência da transferência de dados, especialmente nos processos de backup e replicação de dados, reduzindo a quantidade de dados duplicados armazenados.

Frequência de backup

Muitas dinâmicas influenciam os requisitos de frequência de backup de dados, como a volatilidade dos dados, os requisitos regulatórios, o desempenho do sistema, os recursos de arquitetura e as necessidades operacionais. Organizações com dados altamente dinâmicos ou obrigações regulatórias rigorosas podem optar por backups mais frequentes para minimizar o risco de perda de dados e garantir a conformidade. Por outro lado, empresas com dados relativamente estáveis ou supervisão regulatória menos rigorosa podem escolher backups menos frequentes, balanceamento da proteção de dados, custos do backup de dados e despesas gerais de manutenção. Em última análise, a frequência ideal de backup é determinada pela avaliação cuidadosa dos requisitos regulatórios, pelas necessidades particulares, pela tolerância ao risco e pelos recursos de uma organização.

Backups locais e externos

A necessidade de backups locais e externos deve ser equilibrada, pois eles são fundamentais para proteger dados críticos e garantir a continuidade dos negócios. Os [[backups locais]] envolvem o armazenamento de dados no próprio local (no mesmo ambiente dos sistemas protegidos), em dispositivos como discos rígidos ou fitas, para garantir acesso e recuperação rápidos em caso de perda de dados, corrupção ou falhas de sistema. Por outro lado, os [[backups fora do local]] envolvem a transferência de dados para um ambiente remoto, garantindo proteção contra desastres naturais, roubo e outras ameaças físicas à infraestrutura local, além de possibilitar a recuperação em casos de perda catastrófica de sistemas, como pode ocorrer em infecções por ransomware, por exemplo.

Nota:

Ransomwares representam uma ameaça significativa para empresas e organizações ao criptografar dados vitais e exigir um resgate por sua liberação. Em muitos casos, os ataques de ransomware também têm como alvo a infraestrutura de backup, o que dificulta os esforços de recuperação e exacerba ainda mais o impacto do ataque. Os perpetradores geralmente empregam técnicas avançadas para se infiltrar e comprometer o sistema primário e de backup, tornando-os inúteis quando necessário. As organizações podem implementar várias estratégias para se defender contra este risco, como manter backups fisicamente desconectados da rede, o que impede ativamente que ransomwares tenham acesso a eles e os criptografem.

Validação de recuperação

Técnicas de validação de [[recuperação]] crítica desempenham um papel fundamental para garantir a eficácia e a confiabilidade das estratégias de backup. As organizações podem identificar possíveis problemas e fraquezas em seus processos de recuperação de dados ao testar backups e realizar as melhorias necessárias. Uma técnica comum é o teste de recuperação completa, que envolve restaurar um sistema inteiro a partir do backup, colocá-lo em um ambiente separado e verificar o sistema recuperado totalmente funcional. Este método ajuda a garantir que todos os componentes críticos, como sistemas operacionais, aplicativos e dados, possam ser restaurados e funcionem conforme o esperado.

Outra estratégia é o teste de recuperação parcial, em que arquivos, pastas ou bancos de dados selecionados são restaurados para validar a integridade e consistência de subconjuntos de dados específicos. As organizações podem realizar auditorias regulares de backup, verificando os registros de backup, cronogramas e configurações para garantir que os backups sejam criados e mantidos conforme pretendido e necessário. Além disso, simular cenários de recuperação de desastres, como falhas de hardware ou ataques de ransomware, fornece informações valiosas sobre a preparação e a resiliência de uma organização. As estratégias de validação de recuperação são essenciais porque os backups podem ser concluídos com “100% de sucesso”, mas mascaram problemas até que o conjunto de backup seja usado para uma recuperação.

Além disso, muitas organizações desconhecem o tempo necessário para realizar uma recuperação, que geralmente é muito mais longo do que o previsto.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

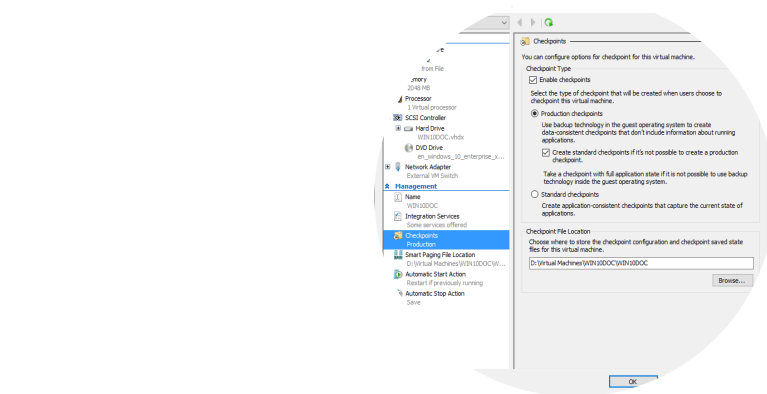
Snapshots

[[Snapshots](#)] desempenham um papel fundamental na proteção e recuperação de dados, pois capturam o estado de um sistema em um momento específico. Snapshots de máquina virtual (VM), filesystem e rede de área de armazenamento (SAN) são três tipos diferentes, e cada uma tem como alvo um nível específico da hierarquia de armazenamento.

- Os **snapshots de VM**, como aqueles criados no VMware vSphere ou no Microsoft Hyper-V, capturam o estado de uma máquina virtual, o que inclui sua memória, armazenamento e configurações. Isto permite que os administradores revertam a VM para um estado anterior em caso de falhas, corrupção de dados ou durante o teste de software.
- Os **snapshots do filesystem**, como aqueles fornecidos por ZFS ou Btrfs, registram o estado de um sistema de arquivos em um determinado momento, para que os usuários recuperem arquivos excluídos acidentalmente ou restaurem versões anteriores de arquivos em caso de corrupção de dados.
- Os **snapshots da SAN** são obtidos na camada de armazenamento no bloco dentro de uma rede da área de armazenamento. Como exemplos, há snapshots de sistemas de armazenamento NetApp ou Dell EMC, que registram o estado de todo o volume de armazenamento, o que permite a recuperação rápida de grandes conjuntos de dados e aplicativos.

Ao utilizar snapshots de VM, filesystem e SAN, as organizações conseguem aprimorar suas estratégias de proteção e recuperação de dados, o que garante a disponibilidade e a integridade de seus dados em diferentes camadas e sistemas de armazenamento.

Figura 1. Seção de configuração de ponto de verificação de uma máquina virtual Hyper-V. Os pontos de verificação referem-se à implementação da funcionalidade de snapshot da Microsoft.



Captura de tela usada com permissão da Microsoft.

Descrição

Um menu suspenso no canto superior esquerdo exibe: WIN10DOC. A janela está dividida em duas partes. A parte esquerda possui o cabeçalho hardware na parte superior e gerenciamento na parte inferior. O cabeçalho "hardware" possui subtítulos: hardware, firmware, memória, processador, controlador SCSI e adaptador de rede. O cabeçalho "gerenciamento" possui subitens: nome, serviços de integração, checkpoints (selecionado), local do arquivo de smart paging, ação de início automático e ação de parada automática.

A parte à direita é intitulada "checkpoints". O texto abaixo informa: você pode configurar opções de checkpoint para esta máquina virtual. Tipo de checkpoint: caixa de seleção "habilitar checkpoints" selecionada. O texto abaixo informa: selecione o tipo de checkpoint que será criado quando os usuários escolherem fazer checkpoint nesta máquina virtual. O botão de opção "checkpoints de produção" está selecionado. O texto abaixo informa: use a tecnologia de backup no sistema operacional convidado para criar checkpoints consistentes de dados que não incluam informações sobre aplicativos em execução. A caixa de seleção "criar checkpoints padrão caso não seja possível criar um checkpoint de produção" está selecionada. O texto abaixo informa: faça um checkpoint com o estado completo do aplicativo caso não seja possível usar a tecnologia de backup dentro do sistema operacional convidado. O botão de opção "checkpoints padrão" não está selecionado. O texto abaixo informa: crie checkpoints consistentes de aplicativos que capturem o estado atual dos aplicativos. Abaixo está uma seção intitulada "localização do arquivo de checkpoint". Os botões "Ok" (selecionado), "Cancelar" e "Aplicar" estão no canto inferior direito.

Replicação e registro no diário

Replicação e registro no diário são métodos de proteção de dados que garantem a disponibilidade e integridade dos dados graças ao registro de várias cópias e monitoramento das alterações nos dados.

A replicação envolve a criação e manutenção de cópias exatas de dados em diferentes sistemas ou locais de armazenamento. As organizações podem se proteger contra a perda de dados devido a falhas de hardware, erros humanos ou ataques mal-intencionados ao manter cópias adicionais dos dados. No caso de uma falha, os dados replicados podem ser utilizados para restaurar o sistema ao seu estado original.

Um exemplo prático de replicação é o **espelhamento do banco** de dados, em que uma organização mantém bancos de dados espelhados primários e secundários. Quaisquer alterações feitas no banco de dados primário são replicadas automaticamente no banco de dados secundário, o que garante a consistência e disponibilidade dos dados se o banco de dados primário encontrar algum problema.

Por outro lado, o registro de mudanças nos dados é feito em um log separado e dedicado, conhecido como diário. As organizações conseguem rastrear e monitorar as modificações de dados e reverter para estados anteriores, se necessário. O uso de `[[journaling]]` é benéfico para a recuperação de dados em caso de falhas do sistema. Ele permite que o sistema identifique e desfaça as transações incompletas que possam ter causado inconsistências ou que repita transações que ocorreram após a conclusão do backup completo do sistema. Isto fornece maior granularidade para restaurações e reduz consideravelmente a perda de dados. Um exemplo prático desse método é o registro no diário do sistema de arquivos, como o Journaled File System (JFS) ou o New Technology File System (NTFS), com o registro em diário ativado. Estes sistemas de arquivos mantêm um registro de todas as alterações feitas nos arquivos, o que permite a recuperação de dados e verificações de consistência após desligamentos ou falhas inesperadas do sistema.

O registro em diário remoto, a replicação de SAN e a replicação de VM são métodos avançados de proteção de dados que mantêm a disponibilidade e integridade dos dados em vários locais e sistemas. O registro em **diário remoto** cria e mantém um diário de alterações de dados em um local separado e remoto, o que possibilita a recuperação de dados e garante a continuidade dos negócios em caso de falhas locais, desastres naturais ou ataques mal-intencionados.

A **replicação de SAN** duplica os dados de uma SAN para outra em tempo real ou quase em tempo real, oferecendo cópias adicionais e proteção contra falhas de hardware, erros humanos ou corrupção de dados. Esta técnica envolve a replicação síncrona, que garante a consistência dos dados, e a replicação assíncrona, que é mais econômica, mas um pouco menos rigorosa em termos de consistência.

Enquanto isso, a **replicação de VM** cria e mantém uma cópia atualizada de uma máquina virtual em um host ou local separado, o que garante que uma VM secundária possa assumir rapidamente a carga de trabalho no caso de uma falha ou corrupção da VM primária. Ao implementar estes métodos, as organizações podem reforçar suas estratégias de proteção de dados, protegendo-se contra vários riscos e garantindo a disponibilidade e a integridade de seus dados e sistemas críticos.

Criptografia de backups

A criptografia de backups é essencial por vários motivos, principalmente pela segurança de dados, privacidade e conformidade. Ao criptografar backups, as organizações adicionam uma camada extra de proteção contra acesso não autorizado ou roubo, garantindo que dados confidenciais permaneçam ilegíveis sem a chave de descryptografia apropriada. Isso é particularmente crucial para empresas que lidam com dados confidenciais de clientes, propriedade intelectual ou segredos comerciais, pois o acesso não autorizado pode levar a graves danos à reputação, perdas financeiras ou consequências legais.

Cópias de dados confidenciais armazenadas em conjuntos de backup são frequentemente negligenciadas, portanto, muitos setores e jurisdições têm regulamentos que exigem a proteção de dados confidenciais armazenados em backups. Criptografar backups ajuda as organizações a atender a esses requisitos regulamentares e evitar multas, penalidades ou ações legais resultantes da não conformidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Várias circunstâncias comuns podem exigir a destruição de dados dentro de uma organização para garantir a segurança, a conformidade e a gestão adequada dos recursos. No final de um período de retenção de dados, as organizações devem destruir os dados de acordo com as políticas internas e regulamentos externos, otimizando os recursos de armazenamento. A conformidade legal e regulamentar, como a adesão ao Regulamento Geral sobre a Proteção de Dados (RGPD) ou à Lei de Portabilidade e Responsabilidade de Seguros de Saúde (HIPAA), também exige a exclusão ou destruição de dados específicos quando não forem mais necessários ou quando solicitado pelo titular dos dados. A destruição periódica de dados obsoletos ou desatualizados pode ajudar a manter uma utilização eficiente do armazenamento e reduzir o risco de violações de dados.

Além disso, ao descomissionar dispositivos ou sistemas de armazenamento, certifique-se de que todos os dados armazenados sejam destruídos antes do descarte ou reutilização, a fim de evitar o acesso não autorizado a informações confidenciais. É fundamental utilizar métodos adequados ao tipo de mídia de armazenamento que está sendo descomissionada:

Para **discos rígidos (HDDs)**, métodos de apagamento de dados como sobrescrever com zeros ou com múltiplos padrões podem ser eficazes. Esse processo pode envolver uma passagem única de zeros ou padrões mais complexos, com múltiplas passagens, para dificultar tentativas de recuperação dos dados.

Para **unidades de estado sólido (SSDs)**, métodos tradicionais de sobrescrição são menos eficazes devido ao nivelamento de desgaste e à gestão de blocos defeituosos. Nesses casos, utilize comandos como o ATA Secure Erase, projetados para lidar com os desafios específicos da tecnologia SSD, instruindo o firmware da unidade a sanitizar internamente todos os dados armazenados, inclusive aqueles em células de memória inacessíveis marcadas como defeituosas.

Descarte de ativos

Os conceitos de descarte/descomissionamento de ativos focam no tratamento seguro e em conformidade de dados e dispositivos de armazenamento ao final de seu ciclo de vida ou quando não são mais necessários. Alguns conceitos importantes são:

Sanitização: Refere-se ao processo de remoção de informações confidenciais da mídia de armazenamento para evitar acesso não autorizado ou violações de dados. Esse processo usa técnicas especializadas, como apagamento de dados, desmagnetização ou criptografia, para garantir que os dados se tornem irrecuperáveis. A limpeza é particularmente

importante ao redirecionar ou doar dispositivos de armazenamento, pois ajuda a proteger as informações confidenciais da organização e mantém a conformidade com os regulamentos de proteção de dados.

Destruição: Envolve a eliminação física ou eletrônica das informações armazenadas em mídias, tornando-as inacessíveis e irrecuperáveis. Os métodos de destruição física incluem trituração, esmagamento ou incineração de dispositivos de armazenamento, enquanto a destruição eletrônica envolve sobrescrever dados várias vezes ou usar técnicas de desmagnetização para eliminar campos magnéticos em mídias de armazenamento. A destruição é uma etapa crucial no processo de desativação e garante que os dados confidenciais não possam ser recuperados ou usados indevidamente após o descarte dos dispositivos de armazenamento.

Certificação: Refere-se à documentação e à verificação do processo de sanitização ou destruição dos dados. Isso geralmente envolve a obtenção de um certificado de destruição ou limpeza emitido por um prestador de serviços terceirizado respeitável, atestando que os dados foram removidos ou destruídos com segurança de acordo com os padrões e regulamentos do setor. A certificação ajuda as organizações a manter a conformidade com os requisitos de proteção de dados, fornece evidências de devida diligência e reduz o risco de responsabilidades legais. Certificar a destruição de dados sem o envolvimento de uma terceirizada pode ser um desafio, pois essas são empresas que fornecem uma avaliação imparcial.

Figura 1. Software de apagamento de dados Active KillDisk.



Captura de tela utilizada com permissão da LSoft Technologies, Inc.

Descrição

A janela Active KillDisk exibe as informações do drive físico na parte superior e a saída na parte inferior. A janela Erase Disk mostra a opção "Erase Disk" no topo, com os drives físicos listados abaixo. Há dois botões de opção chamados "select all volumes" e "select all unallocated space". A opção "Disk Erase" está selecionada no painel esquerdo. O painel direito exibe as seguintes configurações: o método de exclusão está definido como "One Pass Zeros [1 pass]". Quatro botões aparecem na parte inferior: "restore settings", "show advanced", "start" (selecionado) e "cancel".

Os arquivos excluídos de um disco rígido do tipo magnético não são totalmente apagados. Em vez disso, os setores que contêm os dados são marcados como disponíveis para gravação e os dados que eles contêm são removidos apenas à medida que novos arquivos são adicionados. Da mesma forma, a ferramenta de formato padrão do Windows removerá apenas referências a arquivos e marcará todos os setores como utilizáveis. Por esse motivo, o método padrão de sanitização de um HDD é denominado **sobrescrição**. Isso pode ser feito usando as ferramentas de firmware da unidade ou um programa utilitário. O tipo mais básico de sobrescrição é chamado de preenchimento zero e consiste em substituir cada bit por zero. O preenchimento zero de passagem única pode deixar padrões que podem ser lidos com ferramentas

especializadas. Um método mais seguro é sobrescrever o conteúdo com uma passagem toda de zeros, depois uma passagem toda de uns e, em seguida, uma terceira passagem em um padrão pseudoaleatório. Algumas agências federais exigem mais de três passagens. A sobrescrição pode tomar um tempo considerável, dependendo do número de passagens necessárias.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

As estratégias de redundância são essenciais para o planejamento de recuperação de desastres e continuidade de negócios de uma organização. Essas estratégias incluem o planejamento de continuidade das operações (COOP), que envolve o desenvolvimento de processos e procedimentos para garantir que as funções críticas de negócios possam continuar durante e após uma interrupção. O clustering de alta disponibilidade (HA) utiliza sistemas redundantes que podem assumir automaticamente as operações em caso de falha, minimizando o tempo de inatividade. A redundância de energia garante que a infraestrutura crítica, como datacenters, tenha fontes de energia reserva para continuar as operações durante uma interrupção no fornecimento. A diversidade de fornecedores e a defesa em profundidade envolvem o uso de vários fornecedores e camadas de segurança para reduzir o risco de pontos únicos de falha e aumentar a redundância geral. Testes regulares, incluindo tabletops, testes de failover e simulações, são essenciais para identificar vulnerabilidades, avaliar planos de resposta e melhorar as medidas de redundância. Ao incorporar estratégias de redundância, as organizações podem reduzir os riscos, minimizar o tempo de inatividade e garantir a continuidade de suas funções críticas de negócios.

Objetivos abordados no exame:

- 1.2 Resumir os conceitos fundamentais de segurança.
- 3.4 Explicar a importância da resiliência e recuperação na arquitetura de segurança.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Continuidade de operações (COOP)]] refere-se ao processo de garantir que uma organização consiga manter ou retomar rapidamente suas funções críticas em caso de interrupção, desastre ou crise. Os conceitos e estratégias de COOP visam minimizar o tempo de inatividade, proteger os recursos essenciais e manter a resiliência dos negócios. Os principais elementos de um plano de COOP incluem a identificação das funções críticas dos negócios, o estabelecimento de prioridades e a determinação dos recursos necessários para apoiar essas funções. As estratégias geralmente envolvem a criação de redundância para sistemas e dados de TI, como a implementação de backups remotos, sistemas de failover e soluções de recuperação de desastres. Além disso, as organizações podem considerar acordos de trabalho alternativos, como trabalho remoto ou acordos de colocação, para manter as operações durante uma crise. O desenvolvimento de protocolos claros de comunicação e tomada de decisões garante que os funcionários entendam suas funções e responsabilidades durante uma emergência.

Testes regulares e atualização dos planos de continuidade das operações (COOP) são cruciais para garantir que a organização possa manter as funções essenciais durante e após eventos disruptivos. Cenários realistas para simular diferentes interrupções, como desastres naturais, ataques cibernéticos ou pandemias, devem ser usados para avaliar a eficácia do plano. Os métodos de teste geralmente incluem tabletops, testes funcionais isolados ou exercícios em grande escala. Cada abordagem fornece diferentes níveis de garantia e, portanto, deve usar critérios de avaliação pré-estabelecidos para medir o desempenho. Em resumo, as estratégias de COOP consistem no preparo proativo para interrupções, garantindo que as organizações possam continuar a fornecer serviços essenciais e minimizar o impacto de eventos imprevistos em suas operações.

Backups

Os backups desempenham um papel crítico nos planos de continuidade das operações (COOP), protegendo contra a perda de dados e restaurando sistemas e dados em caso de interrupções. Testes regulares verificam a integridade e a eficácia dos backups. Os testes de backup ajudam a garantir que o processo de backup funcione corretamente: eles simulam vários cenários e permitem que as organizações identifiquem quaisquer problemas ou lacunas no processo de backup e recuperação. Testes de backup validam a capacidade de recuperação de sistemas e dados críticos, reduzindo o risco de perda de dados e minimizando o tempo de inatividade associado a eventos disruptivos. Além disso, os testes de backup permitem que as organizações examinem seus planos de recuperação, avaliem a velocidade e a eficiência de seus sistemas de backup e garantam a conformidade com os requisitos regulamentares. Processos de backup inadequados podem levar a tempo de inatividade prolongado, perda crítica de dados, perdas financeiras, danos à reputação e não conformidade.

Relação com a continuidade de negócios

Continuidade das operações (COOP) e continuidade dos negócios (BC) são conceitos intimamente relacionados que têm como princípio a manutenção do funcionamento contínuo de uma organização durante e após uma interrupção, desastre ou crise. No entanto, eles diferem ligeiramente em termos de escopo e objetivos primários.

A continuidade das operações aborda principalmente a continuidade de funções e serviços críticos dentro de uma organização durante uma emergência ou desastre. Muitas vezes envolve o desenvolvimento e a implementação de estratégias para manter ou restaurar operações essenciais, como sistemas de TI redundantes, backups remotos e

soluções de recuperação de desastres. O COOP geralmente abrange um período mais curto, concentrando-se na resposta imediata a uma interrupção e nas medidas tomadas para retomar as funções críticas o mais rápido possível.

A continuidade dos negócios, por outro lado, adota uma estratégia mais ampla, considerando não apenas a continuidade de funções críticas, mas também a resiliência e recuperação gerais de toda a organização. O planejamento de continuidade dos negócios inclui a avaliação de riscos, o desenvolvimento de estratégias para mitigar esses riscos e a criação de planos para manter ou restaurar as operações de negócios diante de várias ameaças. Isso pode envolver o gerenciamento da cadeia de suprimentos, a segurança e a comunicação dos funcionários, a conformidade legal e regulamentar e a gestão da reputação. A continuidade dos negócios visa garantir a viabilidade a longo prazo de uma organização após uma interrupção e abrange tanto a resposta imediata quanto os esforços de recuperação contínuos.

A continuidade das operações é um dos componentes do conceito mais amplo de continuidade dos negócios. Ambos são focados em manter o funcionamento contínuo de uma organização durante interrupções, mas o COOP está principalmente preocupado com a resposta imediata e a restauração de funções críticas, enquanto a continuidade dos negócios envolve uma perspectiva mais abrangente para garantir a resiliência e recuperação gerais de toda a organização.

Planejamento de capacidade

O [planejamento de capacidade] é um processo fundamental no qual as organizações avaliam suas necessidades de recursos atuais e futuras para garantir que possam atender de forma eficiente aos seus objetivos de negócios. Esse processo envolve a avaliação e a previsão dos recursos necessários em termos de pessoal, tecnologia e infraestrutura para apoiar o crescimento previsto, as mudanças na demanda ou outros fatores que possam afetar as operações. No que diz respeito ao pessoal, o planejamento de capacidade considera o número de funcionários, seus conjuntos de habilidades e a necessidade potencial de treinamento ou contratações adicionais para atender às demandas futuras.

Isso pode envolver a avaliação da produtividade da força de trabalho, a análise das quantidades de pessoal e a identificação de possíveis déficits de habilidades. Em matéria de tecnologia, o planejamento de capacidade abrange a avaliação de recursos de hardware, software e rede necessários para apoiar as operações de negócios, levando em consideração fatores como desempenho, escalabilidade e confiabilidade.

As organizações devem garantir que tenham os recursos tecnológicos certos para lidar com cargas de trabalho crescentes e acomodar novos aplicativos ou serviços. No que se refere à infraestrutura, o planejamento de capacidade envolve a avaliação de instalações físicas, como datacenters e espaços de escritório, para determinar se elas podem acomodar o crescimento projetado e manter a continuidade dos negócios. Isso pode incluir considerações sobre energia, resfriamento e conectividade, bem como planejamento para uma possível expansão ou realocação. As organizações usam vários métodos de planejamento de capacidade, incluindo análise de tendências, benchmarking (avaliação comparativa) e modelagem e simulação, para ajudar a prever suas necessidades. A análise de tendências examina dados históricos para identificar padrões e tendências no uso, demanda e desempenho de recursos.

Entendendo os padrões passados, as organizações podem prever os requisitos de recursos futuros. Esse tipo de análise pode ajudar a identificar possíveis gargalos ou outras áreas que exigem atenção. A técnica de modelagem e simulação usa modelos baseados em computador para simular cenários do mundo real. As organizações podem avaliar o impacto das mudanças na demanda, diferentes estratégias de alocação de recursos ou configurações do sistema para tomar decisões bem informadas e otimizar a alocação de recursos para atender às necessidades previstas. A avaliação comparativa requer uma comparação das métricas de desempenho de uma organização com os padrões ou as práticas

recomendadas do setor. Esse método fornece uma maneira relativamente simples de identificar áreas de melhoria e estabelecer metas de desempenho. Em última análise, o planejamento eficaz da capacidade permite que as organizações otimizem a alocação de recursos, reduzam custos e minimizem o risco de tempo de inatividade ou problemas de desempenho, garantindo que possam continuar a atingir suas metas de negócios e manter uma vantagem competitiva.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Riscos de pessoal associados ao planejamento de capacidade

Os riscos de pessoal associados ao planejamento de capacidade podem incluir insuficiência de pessoal ou déficits de habilidades, resultando na alocação inadequada de recursos ou utilização ineficaz. A falta de treinamento cruzado ou planejamento de sucessão pode criar dependência de indivíduos específicos, aumentando a vulnerabilidade a interrupções. Além disso, a resistência à mudança, a falta de envolvimento dos funcionários ou a comunicação ineficaz podem dificultar operações de segurança bem-sucedidas.

- **Treinamento cruzado:** exige que os funcionários desenvolvam habilidades e conhecimentos fora de suas funções principais para mitigar o risco de depender muito de indivíduos ou equipes específicas. Com o treinamento cruzado de funcionários, as organizações podem garantir que vários indivíduos possam executar tarefas críticas, reduzindo a dependência de um único funcionário ou equipe. O treinamento cruzado promove flexibilidade, resiliência e continuidade na força de trabalho.
- **Planos de trabalho remoto:** estipule estratégias para que os funcionários trabalhem de forma eficaz fora do ambiente tradicional do escritório. Os planos de trabalho remoto definem canais de comunicação, requisitos de tecnologia e expectativas nos acordos de trabalho remoto. Os planos de trabalho remoto estabelecidos permitem que as organizações façam a transição perfeita para operações remotas, garantindo a continuidade dos negócios e minimizando o impacto das interrupções.
- **Estruturas alternativas de hierarquia:** relações substitutas ou temporárias de hierarquia que visam reduzir o risco associado a pontos únicos de falha na gestão ou na tomada de decisões. Mediante a identificação de indivíduos ou equipes provisórias, as organizações podem manter as operações e a tomada de decisões mesmo que o pessoal essencial não esteja disponível.

A comunicação eficaz é fundamental para reduzir o risco durante eventos disruptivos. Canais de comunicação claros e oportunos garantem que funcionários, partes interessadas e clientes recebam informações, instruções e atualizações precisas. A comunicação clara ajuda a gerir expectativas, reduzir a confusão e facilitar respostas coordenadas. A comunicação promove a confiança e o envolvimento dos funcionários, assim como garante que todos estejam alinhados com os planos de resposta da organização. Além disso, a comunicação desempenha um papel vital na disseminação de informações sobre acordos de trabalho alternativos, mudanças nas estruturas hierárquicas e outras atualizações críticas durante um evento disruptivo.

Tecnologias e software associados ao trabalho remoto:

- Rede virtual privada (VPN): fornece acesso seguro à rede e aos recursos internos de uma organização.
- Software de área de trabalho remota: permite acesso remoto a computadores ou áreas de trabalho virtuais no escritório ou às ferramentas usadas pelo suporte técnico e pelas equipes do centro de serviços para dar suporte aos funcionários.
- Ferramentas baseadas em nuvem: plataformas como Microsoft 365, Google Workspace, Dropbox, Slack e muitas outras ferramentas populares permitem a colaboração remota em equipe, o compartilhamento de documentos e a comunicação.
- Software de videoconferência: aplicativos como Zoom, Microsoft Teams ou Webex facilitam reuniões virtuais, chamadas em grupo e compartilhamento de tela.
- Mensagens instantâneas e ferramentas de bate-papo: aplicativos como Slack, Microsoft Teams ou Discord permitem comunicação em tempo real e colaboração rápida.
- Sistemas de telefonia virtual: os sistemas de telefonia baseados em nuvem permitem que os funcionários façam e recebam chamadas remotamente usando seus computadores ou dispositivos móveis.
- Ferramentas de gerenciamento de projetos: plataformas como Trello, Asana ou Jira ajudam no gerenciamento de tarefas, no acompanhamento de projetos e na coordenação de equipes.

Mudanças na capacidade do quadro de funcionários

As demissões podem introduzir uma série de riscos físicos e de segurança cibernética em uma organização, o que torna crucial considerar esses fatores nos esforços de planejamento de capacidade. Funcionários insatisfeitos podem representar um risco significativo à segurança cibernética, pois podem recorrer ao acesso não autorizado ou ao uso indevido de dados e sistemas confidenciais. Além disso, a perda de funcionários experientes pode resultar em transferência insuficiente de conhecimento para a equipe restante, levando a falhas de segurança e configurações incorretas. A revogação inadequada do acesso a sistemas e dados para funcionários demitidos também pode deixar as organizações vulneráveis.

Em termos de riscos físicos, os funcionários desligados podem recorrer ao roubo ou sabotagem de ativos físicos ou, então, podem usar seu conhecimento de protocolos e procedimentos de segurança para comprometer a segurança da organização. O acesso não autorizado às instalações é outra preocupação, caso as credenciais de acesso não sejam revogadas prontamente.

O planejamento de capacidade é essencial no gerenciamento desses riscos. Ele permite que as organizações avaliem os requisitos de recursos e tomem decisões estratégicas sobre as quantidades de pessoal e a alocação de recursos. Ao incorporar possíveis demissões ao planejamento de capacidade, as organizações podem se preparar proativamente para os riscos associados e minimizar seus impactos. A implementação de procedimentos robustos de desligamento, garantindo a transferência adequada de conhecimento e a manutenção de uma forte cultura de segurança entre os funcionários restantes são cruciais para mitigar os riscos. Em suma, considerar os riscos potenciais associados a demissões durante o planejamento de capacidade ajuda as organizações a manter um ambiente seguro e proteger seus ativos valiosos.

Outros riscos associados ao planejamento de capacidade precário

O planejamento de capacidade precário nos âmbitos da tecnologia e da infraestrutura pode ter consequências significativas para a segurança cibernética e física de uma organização. Os sistemas sobrecarregados resultantes do planejamento de capacidade inadequado podem aumentar a suscetibilidade a falhas e ataques de negação de serviço (DoS). Além disso, recursos limitados podem levar à degradação do desempenho, fazendo com que as organizações negligenciem medidas e atualizações de segurança essenciais. A falha em investir nas tecnologias de segurança certas ou em manter a infraestrutura necessária para se proteger contra ameaças emergentes deixa as organizações mais vulneráveis a ataques cibernéticos.

Fisicamente, o planejamento de capacidade precário pode resultar em investimento insuficiente em medidas de segurança, como sistemas de controle de acesso, câmeras de vigilância ou instalações seguras, expondo as organizações a acesso não autorizado ou roubo. A negligência dos requisitos de capacidade para fins de energia e resfriamento pode causar superaquecimento ou falhas de energia nos datacenters, levando a falhas de hardware, perda de dados ou tempo de inatividade. Além disso, o planejamento inadequado para o crescimento futuro pode limitar a capacidade de uma organização de expandir suas operações, afetando potencialmente sua capacidade de resposta a incidentes de segurança ou a implementação de novas medidas de segurança.

Por outro lado, superestimar as necessidades de capacidade durante o planejamento pode afetar negativamente uma organização. O aumento dos custos de despesas desnecessárias com tecnologia, infraestrutura e pessoal sobrecarrega os orçamentos e desvia fundos de outras áreas críticas. A utilização ineficiente de recursos pode levar a baixas taxas de utilização, o que pode afetar negativamente o retorno sobre o investimento (ROI) e a eficácia operacional geral. Superestimar as necessidades de capacidade pode contribuir para um maior consumo de energia, aumentando os custos, a pegada de carbono e o impacto ambiental da organização.

A implantação de mais recursos do que o necessário pode aumentar a complexidade da gestão e manutenção da tecnologia e da infraestrutura. Essa complexidade adicional pode criar desafios para as equipes de TI, dificultando a identificação e a resolução de problemas ou a otimização do desempenho. Além disso, o custo de oportunidade de investir em excesso de capacidade pode ser significativo, pois os recursos podem ser desviados de outros projetos ou iniciativas essenciais, potencialmente dificultando a inovação ou o ganho de mercado.

Para evitar esses problemas potenciais, as organizações devem se esforçar para fazer um planejamento de capacidade equilibrado, considerando as necessidades atuais e futuras, mantendo-se flexíveis e adaptáveis às novas circunstâncias. A revisão e atualização regulares dos planos de capacidade, juntamente do emprego de técnicas como monitoramento, previsão e ajuste de escala dos recursos, podem ajudar as organizações a otimizar a alocação de recursos e reduzir os riscos associados à superestimação das necessidades de capacidade.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A alta disponibilidade é crucial na infraestrutura de TI, garantindo que os sistemas permaneçam funcionais e acessíveis com o mínimo de tempo de inatividade. Ela envolve o design e a implementação de componentes de hardware, servidores, redes, datacenters e locais físicos para tolerância a falhas e redundância. Em uma configuração de alta disponibilidade, componentes de hardware redundantes (como fontes de alimentação, discos rígidos e interfaces de rede) reduzem o risco de falha, permitindo que o sistema continue funcionando se um componente falhar. Os servidores geralmente são implantados em clusters ou configurações emparelhadas, o que permite o failover automático de um servidor primário para um secundário em caso de problema.

Os componentes de rede, incluindo switches, roteadores e balanceadores de carga, também são projetados considerando a redundância para manter uma conectividade perfeita. Como a espinha dorsal da infraestrutura de alta disponibilidade, os datacenters empregam fontes de energia redundantes, sistemas de resfriamento e geradores reserva para garantir a operação contínua.

Além disso, as organizações podem implantar datacenters em locais geograficamente diversos para mitigar o impacto de desastres naturais ou outros eventos de grande escala, aprimorando ainda mais a alta disponibilidade e os recursos de recuperação de desastres.

O conceito de “disponibilidade” pode ser medido durante um período definido, como um ano. A disponibilidade pode ser medida como um valor de tempo em atividade ou como uma porcentagem. Também pode ser calculada como o tempo ou a porcentagem em que um sistema está *indisponível* (tempo de inatividade). A métrica de tempo máximo tolerável de inatividade (MTD) expressa o requisito de disponibilidade para uma determinada função de negócios. A alta disponibilidade é geralmente apresentada como 24x7 (24 horas por dia, 7 dias por semana) ou 24x365 (24 horas por dia, 365 dias por ano). Para um sistema crítico, a disponibilidade é apresentada usando o termo “noves”, como dois noves (99%) até cinco ou seis noves (99,9999%). A tabela a seguir identifica a quantidade máxima de tempos de inatividade que cada um dos “noves” representa:

Valor de noves	Disponibilidade	Tempo de inatividade anual (hh:mm:ss)
Seis	99,9999%	00:00:32

Valor de nove	Disponibilidade	Tempo de inatividade anual (hh:mm:ss)
Cinco	99,999%	00:05:15
Quatro	99,99%	00:52:34
Três	99,9%	08:45:36
Dois	99%	87:36:00

Cinco	99,999%	00:05:15
Quatro	99,99%	00:52:34
Três	99,9%	08:45:36
Dois	99%	87:36:00

O tempo de inatividade é calculado pela soma dos intervalos de manutenção programada, mais as interrupções não planejadas ao longo do período.

Nota:

A disponibilidade do sistema pode se referir a um processo geral, mas também à disponibilidade no âmbito de um servidor ou componente individual.

Escalabilidade e elasticidade

A alta disponibilidade também implica que um sistema pode lidar com o rápido crescimento da demanda. Essas propriedades são chamadas de escalabilidade e elasticidade. A escalabilidade é a capacidade de aumentar os recursos para atender à demanda em uma proporção de custo semelhante. Em outras palavras, se a demanda pelo serviço dobrar, os custos não serão maiores do que o dobro. Há dois tipos de escalabilidade:

- Aumentar a escala horizontalmente consiste em adicionar recursos em paralelo com os recursos existentes.
- Aumentar a escala verticalmente significa elevar a potência dos recursos existentes.

Elasticidade refere-se à capacidade do sistema de lidar com mudanças sob demanda, em tempo real. Um sistema com alta elasticidade não sofrerá perda de serviço ou desempenho se a demanda aumentar repentinamente.

Tolerância a falhas e redundância

Um sistema que pode apresentar falhas e ainda assim continuar fornecendo o mesmo nível de serviço (ou um nível muito próximo) é considerado[[tolerante a falhas]]. A tolerância a falhas é frequentemente alcançada por meio da implementação de [[redundância]] em componentes críticos e pontos únicos de falha. Um componente redundante é aquele que não é essencial para o funcionamento normal de um sistema mas que permite ao sistema se recuperar da falha de outro componente.

Considerações sobre o local

Os ambientes corporativos geralmente fornecem resiliência em termos do local. Um local de processamento ou recuperação alternativo é um local que pode fornecer o mesmo nível de serviço (ou equivalente). Um local de processamento alternativo pode estar sempre disponível e em uso, enquanto um local de recuperação pode levar mais tempo para ser configurado ou ser usado apenas em uma emergência.

As operações são projetadas para fazer failover para o novo site até que o site anterior possa ser colocado online novamente. O failover é uma técnica que garante que um componente, dispositivo, aplicativo ou site redundante possa assumir de forma rápida e eficiente a funcionalidade de um ativo que falhou. Por exemplo, os balanceadores de carga fornecem failover no caso de um ou mais servidores ou sites por trás do balanceador de carga estarem inativos ou demorarem muito para responder. Assim que o balanceador de carga detectar isso, ele redirecionará o tráfego de entrada para um servidor ou site de processamento alternativo. Assim, servidores redundantes no pool do balanceador de carga garantem que não haja interrupção ou apenas interrupção mínima do serviço.

A resiliência do site é descrita como hot (quente), warm (morna) ou cold (fria):

- Um [[site hot]] pode assumir em failover quase imediatamente. Isso geralmente significa que o site é de propriedade da organização e está pronto para ser implementado. Por exemplo, um site hot pode consistir em um prédio com equipamento de computador operacional mantido atualizado com um conjunto de dados ao vivo.
- Um [[site warm]] pode ser semelhante, mas com a exigência de que o conjunto de dados mais recente precise ser carregado.
- Um [[site cold]] leva mais tempo para configurar. Um site frio pode ser um prédio vazio com um contrato de arrendamento em vigor para instalar qualquer equipamento necessário quando necessário.

Fornecer redundância nessa escala geralmente é muito complicado e caro. Outro problema é que a criação de sites e dados duplicados também duplica (ou mais que mais) a complexidade de proteger os recursos. Os mesmos procedimentos de segurança que se aplicam à cópia principal devem também ser aplicados aos sites redundantes, sistemas sobressalentes e dados de backup.

[[Dispersão geográfica]] refere-se à distribuição de sites de recuperação em diferentes localidades para fins de recuperação de desastres (DR). O conceito visa garantir que os locais de recuperação estejam localizados distantes o suficiente para minimizar o impacto de desastres regionais, como calamidades naturais ou incidentes localizados. Ao dispersar estrategicamente os locais de recuperação, as organizações podem garantir a resiliência de suas estratégias de recuperação e reduzir o risco de um único evento catastrófico afetar todas as operações comerciais.

Nuvem como recuperação de desastres (DR)

Vários fatores levam as organizações a usar serviços em nuvem para redundância de datacenter ou site. A eficiência de custos desempenha um papel significativo, pois os provedores de nuvem oferecem opções de redundância e backup mais acessíveis devido às suas economias de escala.

Nota:

“Economias de escala” é um conceito que se refere às vantagens de custo que as empresas podem alcançar quando aumentam a produção e a saída. Essencialmente, quanto mais uma empresa produz, mais barato se torna entregar esses produtos.

A escalabilidade dos serviços em nuvem permite que as empresas incorporem recursos redundantes sem provisionamento excessivo de recursos. Por exemplo, a diversidade geográfica fornecida pelos provedores de nuvem ajuda a proteger contra interrupções ou desastres regionais, mas incorporar esse tipo de redundância a uma organização privada seria proibitivo, em termos de custo, e injustificado.

A implementação mais rápida de recursos ao usar plataformas em nuvem permite que as organizações configurem e implementem sistemas redundantes rapidamente, muito mais rapidamente do que poderia ser feito ao construir a infraestrutura do zero.

O gerenciamento simplificado é outro fator crítico, com provedores de nuvem oferecendo ferramentas e serviços que reduzem a complexidade do gerenciamento de infraestrutura redundante. A melhoria da segurança e da conformidade também são considerações importantes, pois os provedores de nuvem investem pesadamente nessas áreas, ajudando as organizações a atender aos requisitos regulatórios de proteção de dados e redundância.

Teste de redundância e alta disponibilidade

O teste de tecnologias de alta disponibilidade, balanceamento de carga e failover é fundamental, tendo sido projetado para avaliar a capacidade de permanecer operacional durante cargas de trabalho pesadas, falhas de componentes ou manutenção programada.

- O **teste de carga** incorpora ferramentas de software especializadas para validar o desempenho de um sistema sob cargas esperadas ou de pico e identificar gargalos ou problemas de escalabilidade.
- O **teste de failover** se concentra na validação de processos de failover para garantir uma transição perfeita entre a infraestrutura primária e secundária.
- Os **sistemas de monitoramento de testes** validam a detecção e resposta eficazes a falhas e problemas de desempenho.

Práticas de teste robustas permitem que as organizações garantam que as tecnologias de alta disponibilidade, balanceamento de carga e failover cumpram efetivamente seu propósito de minimizar interrupções inesperadas e maximizar o desempenho.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Enquanto o balanceamento de carga distribui o tráfego entre nós de processamento independentes, o cluster permite que múltiplos nós redundantes de processamento compartilhem dados entre si para aceitar conexões. Isso fornece redundância. Se um dos nós no [[cluster]] parar de funcionar, as conexões podem executar [[failover]] para um nó de trabalho. Para os clientes, o cluster parece ser um único servidor. Um balanceador de carga distribui solicitações de cliente entre nós de servidor disponíveis em uma farm ou pool e está geralmente associado ao gerenciamento de tráfego da Web, enquanto os clusters são usados para fornecer redundância e alta disponibilidade para sistemas como bancos de dados, servidores de arquivos e outros.

Virtual

Por exemplo, uma organização pode querer provisionar dois dispositivos de balanceamento de carga para que, se um falhar, o outro ainda possa lidar com conexões de cliente. Ao contrário do balanceamento de carga com um único dispositivo, o IP público usado para acessar o serviço é compartilhado entre as duas instâncias no cluster. Esta disposição é referida como um IP virtual ou endereço compartilhado ou flutuante. As instâncias são configuradas com uma conexão privada, na qual cada uma é identificada por seu endereço IP “real”. Essa conexão executa um protocolo de redundância, como o CARP (Common Address Redundancy Protocol), permitindo que o nó ativo “possua” o IP virtual e responda às conexões. O protocolo de redundância também implementa um mecanismo de heartbeat para permitir failover para o nó passivo se o ativo sofrer falhas.

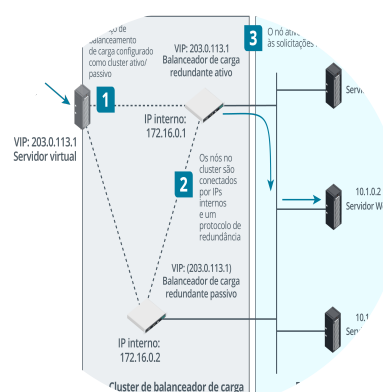


Figura 1. Topologia da arquitetura de balanceamento de carga em cluster.

Imagens © 123RF.com.

Descrição

O cluster de balanceamento de carga à esquerda é composto por um servidor virtual, um balanceador de carga redundante ativo e um balanceador de carga redundante passivo. A fazenda de servidores web à direita é composta por três servidores web. Os primeiros passos são:

1. Serviço de balanceamento de carga configurado como cluster ativo ou passivo.
2. Os nós do cluster são conectados por IPs internos e por um protocolo de redundância.
3. O nó ativo responde às solicitações no IP virtual.

Clustering ativo/passivo (A/P) e ativo/ativo (A/A)

No exemplo anterior, se um nó estiver ativo, o outro está passivo. Isso é chamado de clustering ativo/passivo. A maior vantagem das configurações ativas/passivas é que o desempenho não é afetado negativamente durante o failover. No entanto, há custos mais altos de hardware e sistema operacional devido à capacidade não utilizada.

Um cluster ativo/ativo significa que ambos os nós estão processando conexões simultaneamente. Isso permite que o administrador use a capacidade máxima do hardware disponível enquanto todos os nós estão funcionais. No caso de um failover, a carga de trabalho do nó com falha é imediata e transparentemente deslocada para o outro nó. Nesse momento, a carga de trabalho no nó ou nós restantes é maior e o desempenho é degradado.

****Configurações N+1 e N+M:****Em uma configuração padrão ativa/passiva, cada nó ativo deve ser acompanhado por um nó passivo. Para reduzir os custos associados aos nós passivos, utilizam-se as configurações N+1 e N+M:

- ****Configuração N+1:****Nesse caso, um único nó passivo é compartilhado entre vários nós ativos. Por exemplo, com cinco nós ativos, em vez de possuir cinco nós passivos, apenas um nó passivo é provisionado para assumir em caso de falha de qualquer um dos nós ativos. Essa configuração reduz significativamente o número de nós passivos necessários.
- ****Configuração N+M:****Nesta configuração, vários nós passivos são compartilhados entre vários nós ativos. Por exemplo, com dez nós ativos, podem estar disponíveis dois ou três nós passivos. Esses nós passivos podem assumir em caso de falhas, oferecendo um equilíbrio entre redundância e eficiência de custos.

Clustering de aplicativos

O clustering também é muito comumente usado para fornecer serviços de aplicativos tolerantes a falhas. Se um servidor de aplicativos sofrer uma falha no meio de uma sessão, os dados do estado da sessão serão perdidos. O clustering de aplicativos permite que os servidores no cluster comuniquem informações de sessão entre si. Por exemplo, se um usuário fizer login em uma instância, a próxima sessão poderá ser iniciada em outra instância e o novo servidor poderá acessar os cookies ou outras informações usadas para estabelecer o login.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Todos os tipos de sistemas de computador requerem uma fonte de alimentação estável para operar. Eventos elétricos, como picos ou surtos de tensão, podem travar computadores e aparelhos de rede, enquanto a perda de energia com eventos de subtensão ou falhas de energia fará com que o equipamento falhe. O gerenciamento de energia significa implantar sistemas para garantir que o equipamento esteja protegido contra esses eventos e que as operações de rede possam continuar ininterruptas ou ser recuperadas rapidamente.

Fontes de alimentação duplas

É provável que um servidor ou gabinete de aparelho de classe empresarial apresente duas ou mais unidades de fonte de alimentação (PSUs) para redundância. Uma PSU de conexão automática pode ser substituída (em caso de falha) sem desligar o sistema.

Unidades de distribuição de energia gerenciadas (PDUs)

Os circuitos elétricos que fornecem energia da rede a um rack, armário de rede ou sala de servidores devem ser suficientes para atender à capacidade de carga de todos os equipamentos instalados, além de oferecer uma margem para expansão. Consequentemente, os circuitos para uma sala de servidores serão tipicamente de maior capacidade do que os circuitos domésticos ou de escritório (30 ou 60 amperes em oposição a 13 amperes, por exemplo). Esses circuitos podem ser executados por meio de uma [[unidade de distribuição de energia (PDU)]] . Estas incluem circuitos para “limpar” ou filtrar o sinal elétrico; fornecer proteção contra picos, surtos e eventos de subtensão; e integrar-se a fontes de alimentação ininterruptas (Uninterruptible Power Supply, UPS). As PDUs gerenciadas suportam funções remotas de monitoramento de energia, como relatar carga e status, ligar e desligar uma tomada ou ligar tomadas em uma sequência específica.

Backups de bateria e fontes de alimentação ininterrupta (UPSs)

Se houver falta de energia elétrica, a operação do sistema pode ser sustentada por alguns minutos ou horas (dependendo da carga) usando uma bateria de backup. Uma bateria de backup pode ser provisionada no nível do componente para unidades de disco e matrizes RAID. A bateria protege todas as operações de leitura e gravação em cache no momento da falta de energia. No nível de sistema, um [[no-break (UPS)]] fornecerá uma fonte de energia temporária em caso de perda total de energia elétrica. Isso pode variar de alguns minutos, como em modelos classificados para uso com computadores de mesa, a horas, para sistemas empresariais. Em sua forma mais simples, uma UPS compreende um banco de baterias e seu circuito de carregamento, além de um inversor para gerar tensão de CA a partir da tensão de CC fornecida pelas baterias.

A UPS proporciona tempo suficiente para fazer failover para uma fonte de alimentação alternativa, como um gerador em espera. Se não houver uma fonte de alimentação secundária, uma UPS permitirá que o administrador pelo menos desligue o servidor ou o aparelho corretamente — os usuários podem salvar arquivos e o sistema operacional pode

concluir as rotinas de desligamento adequadas.

Geradores

Um gerador de energia de reserva pode fornecer energia para todo o prédio, frequentemente por vários dias. A maioria dos geradores usa diesel, propano ou gás natural como fonte de combustível. Com o diesel e o propano, a principal desvantagem é o armazenamento seguro (o diesel também tem vida útil entre 18 meses e 2 anos); com o gás natural, a questão é um fornecimento confiável de gás em caso de desastre natural. Os datacenters também estão investindo em fontes de energia renováveis, como solar, eólica, geotérmica, células de combustível de hidrogênio e hidrelétrica. A capacidade de usar energia renovável é um forte fator na determinação do melhor local para novos datacenters. Soluções de bateria em grande escala, como o Powerpack da Tesla ([tesla.com/powerpack](https://www.tesla.com/powerpack)), podem fornecer uma alternativa aos geradores de energia reserva. Também existem tecnologias emergentes que utilizam todos os recursos de bateria de um data center como uma microrrede para armazenamento de energia (<https://www.scientificamerican.com/article/how-big-batteries-at-data-centers-could-replace-power-plants/>).

Nota:

Uma UPS é sempre necessária para proteger contra qualquer interrupção nos serviços de computação, uma vez que um gerador de reserva não pode ser colocado online com rapidez suficiente para responder a uma falha de energia. A energia do gerador é normalmente introduzida por meio de interruptores de transferência que podem operar manual ou automaticamente. A UPS deve ser dimensionada adequadamente para lidar com os requisitos de energia durante o processo de transferência.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A diversidade de plataformas é um conceito em cibersegurança que se refere ao uso de diversas tecnologias, sistemas operacionais e componentes de hardware ou software na infraestrutura de uma organização. Ao incorporar uma variedade de plataformas, as empresas podem reduzir o risco de uma única vulnerabilidade ou ataque afetar toda a sua infraestrutura. Essa abordagem é importante para as operações de segurança cibernética por ajudar a criar um ambiente mais resiliente que pode resistir melhor às ameaças cibernéticas.

Quando uma organização depende de uma única tecnologia ou plataforma, um invasor que descobre uma vulnerabilidade pode potencialmente comprometer todo o sistema. No entanto, com a diversidade de plataformas, mesmo que um componente seja comprometido, outras partes do sistema permanecem seguras, limitando os danos potenciais. Além disso, um cenário tecnológico diversificado pode tornar a navegação mais desafiadora para os agentes de ameaças, pois eles devem estar familiarizados com múltiplas plataformas e técnicas de exploração. Dessa forma, a diversidade de plataformas impede possíveis invasores e contribui para a robustez geral da postura de segurança cibernética de uma organização.

Defesa total

A defesa em profundidade é uma estratégia abrangente de segurança cibernética que enfatiza a implementação de várias camadas de proteção para proteger as informações e a infraestrutura de uma organização. Esta abordagem baseia-se no princípio de que nenhuma medida de segurança única pode proteger completamente contra todas as ameaças. Ao implantar uma variedade de defesas em diferentes níveis, as organizações podem criar uma postura de segurança mais resiliente que pode resistir a uma ampla gama de ataques. Por exemplo, uma estratégia defensiva em profundidade pode incluir medidas de segurança de perímetro, como firewalls e sistemas de detecção de intrusão para proteger contra ameaças externas. As organizações podem implementar segmentação, controles de acesso seguro e monitoramento de tráfego no nível da rede para impedir o acesso não autorizado e conter possíveis violações. As soluções de segurança de endpoint, como software antivírus e proteção de dispositivos, ajudam no hardening de dispositivos individuais, enquanto o gerenciamento regular de patches garante que as vulnerabilidades do software sejam abordadas prontamente.

Além disso, a implementação de métodos de autenticação de usuário fortes, como a autenticação multifator, pode proteger ainda mais o acesso a dados e sistemas confidenciais. Por fim, o treinamento de conscientização de segurança dos funcionários e o planejamento de resposta a incidentes são componentes essenciais de uma estratégia defensiva em profundidade, ajudando a minimizar o erro humano e garantir uma resposta rápida a incidentes de segurança.

Diversidade de fornecedores

A diversidade de fornecedores é essencial por vários motivos, oferecendo benefícios não apenas em termos de segurança cibernética, mas também em resiliência, inovação e competitividade:

- **Cibersegurança:** Dependendo exclusivamente de um único fornecedor para todas as soluções de software e hardware pode criar um ponto único de falha. Toda a infraestrutura pode estar em risco se uma vulnerabilidade for descoberta nos produtos desse fornecedor. A diversidade de fornecedores introduz várias tecnologias, reduzindo o impacto de uma única vulnerabilidade e tornando mais difícil para os invasores explorarem todo o sistema.
- **Resiliência dos negócios:** A diversidade de fornecedores reduz o risco associado ao vendor lock-in e garante que as operações de uma organização não dependam exclusivamente dos produtos ou serviços de um único fornecedor. Se um fornecedor parar de fazer negócios, for à falência ou sofrer uma interrupção significativa, ter alternativas ajuda a manter a continuidade dos negócios.
- **Inovação:** A diversidade de fornecedores proporciona diferentes perspectivas, ideias e tecnologias. Aproveitar soluções de vários fornecedores pode levar a uma infraestrutura de TI mais inovadora e ágil, posicionando

melhor uma organização para se adaptar às tendências e tecnologias emergentes.

- **Concorrência:** A diversidade de fornecedores estimula a concorrência saudável no mercado, o que pode resultar em melhores preços, aprimoramento de recursos dos produtos e suporte ao cliente de maior qualidade. Ao envolver vários fornecedores, as organizações podem incentivar a melhoria contínua e obter melhor valor para seus investimentos.
- **Personalização e flexibilidade:** Diferentes fornecedores oferecem soluções exclusivas que atendem a necessidades específicas, e ter um ecossistema diversificado de fornecedores permite que as organizações escolham a melhor opção para suas necessidades. Essa flexibilidade pode resultar em uma infraestrutura de TI mais bem adaptada e eficaz.
- **Gestão de riscos:** A diversidade de fornecedores contribui para a distribuição dos riscos associados a possíveis falhas de produtos ou serviços, violações de segurança e outros incidentes. As organizações podem gerenciar e mitigar melhor os riscos ao não confiar em um único provedor ou fornecedor de soluções.
- **Conformidade:** Em alguns setores, regulamentos ou padrões podem exigir que as organizações mantenham a diversidade de fornecedores para garantir a conformidade e reduzir o risco de interrupções na cadeia de suprimentos ou violações de segurança.

Nota:

Outros tipos de controles contribuem para a defesa em profundidade, como controles de segurança física que bloqueiam o acesso físico a equipamentos de informática e políticas projetadas para definir o uso apropriado e as consequências da não conformidade.

Estratégias multinuvem

Uma estratégia de várias nuvens oferece vários benefícios para as operações de segurança cibernética e as necessidades de negócios, aproveitando os pontos fortes de vários provedores de serviços em nuvem. Essa abordagem aumenta a segurança cibernética diversificando o risco associado a um ponto único de falha, pois vulnerabilidades ou violações no ambiente de um provedor de nuvem são menos propensas a comprometer toda a infraestrutura. Além disso, uma estratégia de várias nuvens pode melhorar a postura de segurança, implementando recursos e serviços de segurança exclusivos oferecidos por diferentes provedores de nuvem. Do ponto de vista comercial, uma abordagem multinuvem promove a independência do fornecedor, reduzindo o risco de aprisionamento a um único fornecedor e garantindo que as organizações possam se adaptar às mudanças nas condições do mercado ou às tendências tecnológicas. Essa estratégia promove uma concorrência saudável entre os provedores de nuvem, muitas vezes levando a preços mais favoráveis e melhores ofertas de serviços. Além disso, uma estratégia que utiliza várias nuvens permite que as organizações otimizem sua infraestrutura de TI selecionando os serviços de nuvem mais adequados para cargas de trabalho ou aplicativos específicos, melhorando o desempenho e a eficiência de custos.

Em um exemplo prático de uma estratégia multinuvem, uma empresa que opera uma grande plataforma de comércio eletrônico pode distribuir cargas de trabalho entre vários provedores de nuvem para alcançar alta disponibilidade, segurança de dados, otimização de desempenho e eficiência de custos. Ao hospedar a infraestrutura primária de aplicativos em um provedor de nuvem e usar outro para backup e recuperação de desastres, a empresa garante operação contínua mesmo durante interrupções. O armazenamento de dados confidenciais de clientes com um provedor de nuvem que oferece recursos avançados de segurança e certificações de conformidade atende aos requisitos regulamentares. Para lidar com as preocupações de latência e desempenho, a empresa pode aproveitar um

provedor de nuvem com uma rede global de locais de borda (edge) para serviços de entrega de conteúdo e armazenamento em cache. Finalmente, serviços de armazenamento e processamento econômicos podem ser usados por outro provedor para análises e relatórios de big data. Essa abordagem multinuvem permite que a empresa de comércio eletrônico construa uma infraestrutura de TI mais resiliente, segura e eficiente, adaptada às suas necessidades específicas.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

[[Tecnologias de deception e disruption]] são ferramentas e técnicas de resiliência em cibersegurança que visam aumentar o custo do planejamento de ataques para o ator de ameaça. Honeypots, honeynets, honeyfiles e honeytokens são ferramentas de cibersegurança utilizadas para detectar e defender contra ataques. [[Honeypots]] são sistemas de chamariz que imitam sistemas e aplicações reais. Eles são projetados para permitir que as equipes de segurança monitorem as atividades dos invasores e coletem informações sobre suas táticas e ferramentas. As honeynets são uma rede de honeypots interconectados que simulam uma rede inteira, proporcionando um ambiente mais extenso e realista para os invasores se envolverem. Honeyfiles são arquivos falsos que parecem conter informações confidenciais, usados para detectar tentativas de acesso e roubo de dados. Honeytokens são credenciais falsas, credenciais de login ou outros tipos de dados usados para distrair os invasores, disparar alertas e fornecer informações sobre a atividade do invasor.

Ao implementar essas ferramentas, as organizações podem detectar e monitorar ataques, coletar informações sobre os invasores e seus métodos e se defender proativamente contra ataques futuros. Essas ferramentas também podem fornecer uma camada adicional de defesa, desviando a atenção dos invasores de sistemas e aplicativos reais, reduzindo o risco de ataques bem-sucedidos.

Estratégias de interrupção

Outro tipo de defesa ativa usa estratégias de interrupção. Elas adotam algumas das estratégias de ofuscação usadas por atores maliciosos. O objetivo é aumentar o custo do ataque e limitar os recursos do adversário. Alguns exemplos de estratégias de interrupção incluem o seguinte:

- Usar entradas DNS falsas para listar vários hosts que não existem.
- Configurar um servidor Web com vários diretórios de chamariz ou páginas geradas dinamicamente para retardar a varredura.
- Utilizar port triggering ou spoofing para retornar dados de [[telemetria falsos]] quando um host detecta atividade de varredura de portas. Isso resultará em várias portas sendo falsamente relatadas como abertas e diminuindo a

velocidade da varredura. A telemetria pode se referir a qualquer tipo de medição ou dados retornados por varredura remota. Telemetria falsa semelhante pode ser usada para relatar endereços IP como ativos quando eles não o estão, por exemplo.

- Utilizar um [[DNS sinkhole]] para direcionar o tráfego suspeito para uma rede diferente, como uma honeynet, onde ele pode ser analisado.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Método de ensaio

Testar a resiliência do sistema e a eficácia da resposta a incidentes é crucial para que as organizações se recuperem de interrupções e mantenham a continuidade dos negócios. Ao realizar vários testes, as organizações podem identificar possíveis vulnerabilidades, avaliar a eficiência de suas estratégias de recuperação e melhorar sua preparação geral para incidentes da vida real.

- [[Exercícios tabletop]] envolvem equipes discutindo e analisando cenários hipotéticos para avaliar seus planos de resposta e processos de tomada de decisão. Esses exercícios ajudam a identificar lacunas de conhecimento, comunicação e coordenação, fortalecendo as capacidades de resposta a incidentes da organização. Por exemplo, um tabletop pode simular um ataque de ransomware para testar o quão bem as equipes de TI e de gerenciamento da organização colaboram para mitigar a ameaça e restaurar as operações.
- **Testes de failover** consistem em causar intencionalmente a falha de um sistema ou componente primário para avaliar a transferência automática das operações para um sistema secundário e redundante. Esses testes garantem que os sistemas de backup possam assumir o comando sem interrupções durante um incidente real, minimizando o tempo de inatividade e a perda de dados. Por exemplo, um teste de failover pode simular a falha de um servidor de banco de dados primário para verificar se um servidor em espera pode assumir com sucesso sua função e manter a continuidade do serviço.
- [[Simulações]] são experimentos controlados que replicam cenários do mundo real, permitindo que as organizações avaliem seus processos de resposta a incidentes e a resiliência dos sistemas em condições realistas. Esses testes podem revelar possíveis gargalos, ineficiências ou vulnerabilidades que podem não ser aparentes em testes menos complexos. Por exemplo, uma simulação pode envolver um ataque cibernético visando a infraestrutura de rede da organização para avaliar a eficácia das medidas de segurança e a capacidade de detectar, conter e remediar a ameaça.
- [[Testes de processamento paralelo]] envolvem a execução simultânea dos sistemas primário e de backup para validar a funcionalidade e o desempenho dos sistemas de backup sem interromper as operações normais. Esses

testes ajudam as organizações a garantir que seus sistemas de backup possam lidar com a mesma carga de trabalho que os sistemas primários durante um incidente. Por exemplo, uma organização pode executar testes de processamento paralelo para verificar se um datacenter de backup pode gerenciar o mesmo tráfego e demanda de processamento que o datacenter primário no evento de uma interrupção.

A não realização de testes, como tabletops, testes de failover, simulações e processamento paralelo, pode expor as organizações a riscos significativos. Com esses testes, as organizações podem reconhecer possíveis vulnerabilidades e fraquezas em seus planos de resposta a incidentes e projetos de resiliência do sistema e usar os resultados dos testes para melhorar os planos existentes. Em uma interrupção ou ataque cibernético da vida real, sistemas e procedimentos de resposta não testados podem não funcionar conforme o esperado, levando a tempo de inatividade prolongado, perda de dados e danos à reputação. Além disso, as organizações despreparadas podem enfrentar custos crescentes relacionados à recuperação e mitigação de incidentes e possíveis penalidades regulatórias por não atender aos padrões do setor e aos requisitos de conformidade. Em última análise, a não implementação desses testes pode deixar as organizações inadequadamente preparadas para crises, prejudicando sua capacidade de manter a continuidade dos negócios e proteger ativos valiosos.

Documentação

As práticas de documentação de continuidade de negócios abrangem planejamento, implementação e avaliação. A documentação apoia o processo de teste. A documentação inclui planos de teste que descrevem os objetivos, escopo e métodos de testes e as funções e responsabilidades dos indivíduos envolvidos. Os scripts (ou cenários) de teste fornecem instruções passo a passo para realizar os testes, e os resultados dos testes identificam os pontos fortes e fracos do plano de continuidade de negócios e os recursos técnicos que o apoiam. A documentação é a base para uma comunicação e criação de relatórios claros das atividades. Ela fornece um ponto de referência comum para os envolvidos nos testes de continuidade de negócios e facilita a comunicação eficaz com a administração, as equipes executivas e outras partes interessadas relevantes. As avaliações e certificações de terceiros oferecem uma avaliação objetiva e independente das práticas de teste de uma organização. As avaliações e certificações de terceiros oferecem uma avaliação objetiva, verificação de conformidade, validação da eficácia dos testes, reconhecimento do setor e recomendações para melhoria contínua. Exemplos de avaliações de terceiros incluem avaliações realizadas no âmbito do ISO 22301, PCI DSS e SOC 2.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A segurança física é fundamental para as operações de cibersegurança porque fornece a primeira linha de defesa contra o acesso físico aos ativos críticos de uma organização. A cibersegurança trata da proteção de ativos digitais e dos componentes físicos que abrigam esses ativos, como servidores, datacenters e outras infraestruturas críticas.

Exemplos práticos de medidas de segurança física em operações de cibersegurança incluem mecanismos de controle de acesso, como scanners biométricos, smart cards, key fobs e sistemas de vigilância, incluindo câmeras de vídeo, sensores de movimento e alarmes. Além disso, o fornecimento de energia elétrica de backup, o resfriamento redundante e os sistemas de combate a incêndio são componentes críticos da segurança física em datacenters.

Os controles de acesso físico dependem dos mesmos fundamentos de controle de acesso que a segurança técnica do sistema:

- **Autenticação:** cria listas de acesso e identifica mecanismos para permitir que pessoas aprovadas passem pelas barreiras.
- **Autorização:** cria barreiras ao redor de um recurso para controlar o acesso por meio de pontos de entrada e saída definidos.
- **Contabilidade:** registra quando os pontos de entrada/saída são usados e detecta violações de segurança.

A segurança física é frequentemente implementada por meio da incorporação de zonas. Cada zona é separada por suas próprias barreiras. Um ou mais mecanismos de segurança controlam pontos de entrada e saída nessas barreiras. A progressão por cada zona deve ser cada vez mais restritiva.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Segurança física por meio do design do ambiente

A segurança física por meio do design do ambiente é uma abordagem de segurança que usa o ambiente construído para aumentar a segurança e prevenir o crime. Essa abordagem projeta espaços físicos, edifícios e paisagens para promover recursos de segurança não óbvios. A segurança física por meio do design ambiental pode ser usada em vários ambientes, como bairros residenciais, distritos comerciais, escolas e espaços públicos. Ao incorporar esses princípios de design, as organizações podem aumentar a segurança, impedir atividades criminosas e promover uma

sensação de segurança e bem-estar entre os usuários. Além disso, a segurança física por meio do design ambiental pode ser uma maneira econômica de melhorar a segurança porque incorpora facilmente elementos de design em estruturas novas ou existentes por um custo baixo.

Barricadas e pontos de entrada/saída

Uma barricada é algo que impede o acesso. Como em qualquer sistema de segurança, nenhuma barricada é completamente eficaz; uma parede pode ser escalada e uma fechadura pode ser arrombada. O objetivo das barricadas é canalizar o fluxo de pessoas por meio de pontos de entrada e saída definidos. Cada ponto de entrada deve ter um mecanismo de autenticação para que apenas pessoas autorizadas possam passar. Mecanismos de vigilância eficazes garantem a detecção de tentativas de atravessar uma barreira por outros meios.

Nota:

Os locais físicos com risco de ataque terrorista usam barricadas como bollards (postes curtos e resistentes) e postos de segurança para impedir que os veículos acelerem em direção a um prédio.

Cercas

O exterior de um prédio pode ser protegido por cercas. As cercas de segurança precisam ser transparentes (para que os guardas vejam qualquer tentativa de penetrá-las), robustas (para que sejam difíceis de cortar) e seguras contra escaladas (o que geralmente é conseguido por meio de altura e uso de arame farpado). As cercas são geralmente eficazes, mas a desvantagem é que elas dão uma aparência intimidante ao edifício. Os edifícios que recebem clientes ou o público da empresa podem usar métodos de segurança mais discretos.

Iluminação

A [iluminação] de segurança é extremamente importante para a percepção de que um prédio é seguro durante a noite. Uma iluminação bem projetada ajuda as pessoas a se sentirem seguras, especialmente em áreas públicas ou espaços fechados, como estacionamentos. A iluminação de segurança também atua como um dissuasivo, tornando a entrada não autorizada mais difícil e a vigilância (seja por câmera ou guardas) mais fácil. O design da iluminação precisa levar em conta os níveis gerais de luz, a iluminação de superfícies ou áreas específicas (permitindo que as câmeras realizem o reconhecimento facial, por exemplo) e evitar áreas de sombra e brilho.

Bollards

[Bollards] geralmente são postes verticais curtos feitos de aço, concreto ou outros materiais igualmente resistentes e são instalados em intervalos ao redor de um perímetro ou entrada. Às vezes, os bollards não são óbvios e têm o formato de esculturas ou elementos de design dos edifícios. Eles podem ser fixos ou retráteis, e alguns modelos podem ser levantados ou abaixados de forma remota. Os bollards podem ter vários propósitos, como proteger os pedestres do tráfego de veículos, impedir o acesso não autorizado de veículos e fornecer segurança de perímetro para infraestruturas

e instalações críticas. Eles são frequentemente usados para proteger edifícios governamentais, aeroportos, estádios, entradas de lojas e outros espaços públicos. Além de impedir que veículos entrem em áreas restritas, os bollards podem ajudar a mitigar riscos de ataques e acidentes veiculares.

Figura 1. Os bollards eram usados para proteger a entrada da estação de trem de Reading na Grã-Bretanha.



Imagem do usuário rogerrutter © 123RF.com.

Estruturas existentes

Pode haver algumas opções para ajustar o layout do local em instalações existentes. Quando houver restrições de custos e a necessidade de reutilizar a infraestrutura existente, incorporar os seguintes princípios pode ser útil:

- Localizar zonas seguras, como salas de equipamentos, o mais dentro possível do prédio, evitando paredes externas, portas e janelas.
- Use um design de zona desmilitarizada para o espaço físico. Posicione as áreas de acesso público para que os visitantes não passem perto de zonas seguras. Os mecanismos de segurança em áreas públicas devem ser altamente visíveis para aumentar a dissuasão.
- Use sinalização e avisos para impor a ideia de que a segurança é controlada de forma rigorosa. Além das placas básicas de “não entre”, algumas casas e escritórios também exibem placas das empresas de segurança responsáveis por esses serviços. Isso pode convencer invasores a manterem distância.
- Por outro lado, os pontos de entrada para zonas seguras devem ser discretos. Não permita que um invasor tenha a oportunidade de inspecionar os mecanismos de segurança que protegem essas zonas (ou mesmo saber onde estão). Utilize [[camuflagem industrial]] para tornar prédios e portais que protegem ativos de alto valor discretos, ou crie áreas de isca altamente visíveis para atrair possíveis atores de ameaça.
- Tente minimizar o tráfego entre as zonas. O fluxo de pessoas deve ser de “entrada e saída” em vez de “cruzamento e passagem interna”.
- Dê alta visibilidade a áreas públicas de alto tráfego para impedir o uso dissimulado de gateways, portas de acesso à rede e equipamentos de computador e simplifique a vigilância.
- Em zonas seguras, posicione telas de exibição ou dispositivos de entrada longe de caminhos ou janelas. Use vidro refletivo que oferece visibilidade apenas de dentro para fora para que ninguém possa olhar para dentro pelas janelas.

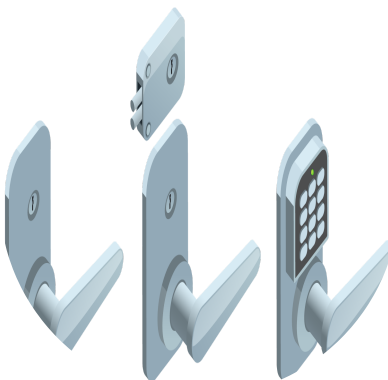


This content is only available on larger screen sizes. Please revisit this page on a larger device.

Para proteger um portão, ele deve ser equipado com uma fechadura. Um portão seguro normalmente terá fechamento e travamento automáticos, em vez de depender do usuário para fechá-lo e trancá-lo. As fechaduras podem ser categorizadas nos seguintes tipos:

- **Física:** são fechaduras convencionais que impedem que a maçaneta da porta seja operada sem o uso de uma chave. Tipos mais caros oferecem maior resistência contra a abertura de fechaduras.
- **Eletrônica:** não utilizam uma chave, em vez disso, operam utilizando um PIN em um teclado eletrônico. Esse tipo de fechadura é chamado também de cifra, combinação ou sem chave (keyless). Uma fechadura inteligente pode ser aberta por meio de um cartão magnético ou contar com um[[leitor de proximidade]] para detectar a presença de um token físico, como um chaveiro sem fio (key fob) ou smart card.

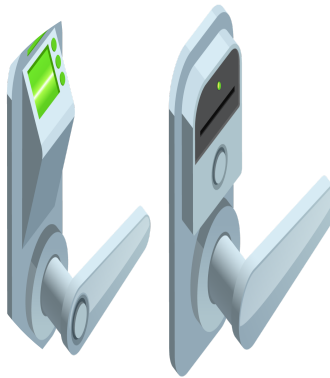
Figura 1. Exemplos genéricos de fechaduras — da esquerda para a direita: fechadura padrão com chave, fechadura com trinco adicional e fechadura com teclado eletrônico.



Imagens do usuário macrovector © 123RF.com.

- **Biométrica:** é uma fechadura integrada a um scanner biométrico.

Figura 2. Exemplos genéricos de um scanner de impressão digital e uma fechadura baseada em token que utiliza um cartão de acesso.



Imagens do usuário macrovector © 123RF.com.

Vestíbulo de controle de acesso

Um vestíbulo de controle de acesso, também conhecido como “mantrap”, é uma medida de segurança que regula a entrada em uma área restrita. Ele utiliza duas portas ou portões interconectados que permitem que apenas um indivíduo passe de cada vez. A primeira porta se abre depois que a pessoa recebe acesso por meio de um sistema de controle de acesso, como um leitor de cartão ou scanner biométrico. Depois que a pessoa entra na área de acesso, a primeira porta se fecha. A segunda porta se abre apenas depois que a primeira porta estiver fechada. Isso garante que apenas uma pessoa entre ou saia de cada vez, impedindo o acesso não autorizado ou o acesso de alguém seguindo uma pessoa autorizada. São frequentemente usados em ambientes de alta segurança, como datacenters, prédios governamentais e instituições financeiras, para oferecer uma camada adicional de controle de segurança física. Eles impedem efetivamente o acesso não autorizado a áreas seguras e protegem ativos confidenciais contra possíveis ataques físicos.

Travas de cabo

Travas de cabo são fixadas a um ponto seguro no chassi do dispositivo. Um chassi de servidor pode vir com um cabo de metal e um slot de segurança Kensington. Além de prender o chassi a um rack ou mesa, a posição do ponto de segurança também impede que o chassi seja aberto sem remover o cabo primeiro.

Crachás de acesso

Crachás de acesso são um componente fundamental da segurança física em organizações de grande porte, onde o controle de acesso a diferentes locais é essencial. Cartões de plástico com tiras magnéticas, chips de identificação por radiofrequência (RFID) ou tecnologia de comunicação a curta distância (Near-Field Communication, NFC) são entregues aos indivíduos autorizados, como funcionários, contratados ou visitantes, em vez de chaves físicas. Os crachás de acesso substituem as chaves físicas, mas fornecem acesso de maneira semelhante. O crachá precisa ser deslizado, tocado ou aproximado de um leitor no access point, como uma porta ou catraca. O leitor se comunica com um sistema de controle para verificar a autenticidade do crachá e o nível de acesso concedido ao portador. Caso o sistema reconheça o crachá como válido e autorizado para aquela área, a porta se destranca, concedendo acesso.

É importante observar que a implementação desse tipo de sistema de controle de acesso requer mecanismos magnéticos de travamento de portas e leitores de cartões de acesso, que dependem de energia elétrica e comunicações de rede em cada access point (como uma porta).

Nota:

Um sistema de controle de acesso físico (Physical Access Control System, PACS) é um componente crítico no gerenciamento e manutenção da segurança dentro de uma instalação. É um sistema projetado para controlar quem pode acessar locais específicos dentro de um prédio ou local. O PACS opera por meio de uma combinação de hardware e software, incluindo cartões ou crachás de acesso, leitores de cartões, painéis de controle de acesso e uma rede de controle centralizada. O sistema PACS fornece recursos valiosos de registro das atividades de acesso dos crachás.

Além de controlar o acesso, os crachás de acesso também servem como forma de identificação, exibindo informações pertinentes sobre o portador, como nome, cargo e fotografia. Isso ajuda a identificar rapidamente os indivíduos dentro de uma instalação e verificar se estão em uma área apropriada à sua função ou propósito. Além disso, os crachás de acesso podem fornecer dados valiosos para auditorias e investigações de segurança. Cada vez que um crachá é usado, um sistema PACS pode registrar a hora, o local e a identidade associados ao evento de acesso. Isso pode ser crucial para investigar violações de segurança, entender padrões de movimento e até mesmo planejar estratégias de evacuação de emergência.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

A vigilância costuma ser uma segunda camada de segurança projetada para melhorar a resiliência das entradas de um perímetro. A vigilância pode ser focada em áreas de perímetro ou dentro de zonas de segurança. Guardas de segurança, armados ou não, podem ser posicionados em frente a um local ou nas suas proximidades para protegê-lo. Eles podem monitorar pontos de verificação críticos e verificar a identificação, permitir ou não o acesso e registrar ocorrências de entrada física. Eles também fornecem um elemento visual dissuasivo e podem aplicar seu próprio conhecimento e intuição para lidar com possíveis violações de segurança. A presença visível de seguranças é um mecanismo de detecção e dissuasão de invasores muito eficaz, mas proporcionalmente caro. Pode não ser possível colocar seguranças dentro de certas zonas por uma impossibilidade de conceder a autorização de segurança apropriada a eles. O treinamento e a triagem dos seguranças são essenciais.

A [[vigilância por vídeo]] é uma alternativa mais econômica para monitoramento do que manter seguranças separados em cada entrada ou zona, embora a implementação ainda possa ser onerosa caso a infraestrutura não esteja previamente instalada no local. Também tem um efeito dissuasivo bastante eficaz. A outra grande vantagem é que todo

movimento e acesso pode ser registrado. A principal desvantagem em comparação com a presença de seguranças é que os tempos de resposta são maiores e a segurança pode ser comprometida se não houver pessoal suficiente para monitorar os feeds das câmeras.

Figura 1. CFTV instalado para monitorar uma sala de servidores



Imagem de Dario Lo Presti © 123RF.com.

As câmeras em uma rede de circuito fechado de televisão (CFTV) são normalmente conectadas a um multiplexador usando cabos coaxiais. O multiplexador pode exibir imagens das câmeras em uma ou mais telas, permitir que o operador controle as funções da câmera e grave as imagens em fita ou disco rígido. Os sistemas de câmeras mais recentes podem ser conectados a uma rede IP, usando cabeamento de dados normal.

Os sistemas de câmera e robótica podem usar IA e aprendizado de máquina para implementar segurança física inteligente([theverge.com/2018/1/23/16907238/artificial-intelligence-surveillance-cameras-security](https://www.theverge.com/2018/1/23/16907238/artificial-intelligence-surveillance-cameras-security) (<https://www.theverge.com/2018/1/23/16907238/artificial-intelligence-surveillance-cameras-security>)):

- **Reconhecimento de movimento:** acontece quando o sistema de câmeras é configurado com tecnologia de identificação da forma de andar. Isso significa que o sistema pode gerar um alerta quando qualquer pessoa dentro do campo de visão da câmera se mover em um padrão que não corresponda a um indivíduo conhecido e autorizado.
- **Detecção de objetos:** acontece quando o sistema de câmeras consegue detectar alterações no ambiente, como um servidor ausente ou um dispositivo desconhecido conectado a uma porta de parede.
- **Drones/UAV** — câmeras montadas em drones podem cobrir áreas mais amplas do que o patrulhamento em solo ([zdnet.com/article/best-security-surveillance-drones-for-business](https://www.zdnet.com/article/best-security-surveillance-drones-for-business) (<https://www.zdnet.com/article/best-security-surveillance-drones-for-business>)).



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Os alarmes desempenham um papel vital na segurança física, complementando outros controles de segurança. Os alarmes alertam o pessoal de segurança e os ocupantes do edifício sobre possíveis ameaças ou violações. Eles são controles de detecção e dissuasão, notificando problemas e desencorajando o acesso não autorizado e atividades criminosas. Os alarmes são frequentemente integrados a outros controles de segurança física, como sistemas de controle de acesso, câmeras de vigilância ou sensores de movimento, para aumentar sua eficácia. A lista a seguir descreve vários tipos comuns de alarmes:

- **Circuito:** Utiliza um alarme baseado em circuito que é acionado quando o circuito é aberto ou fechado, dependendo do tipo de alarme. Por exemplo, ele pode ser acionado pela abertura de uma porta ou janela ou por uma cerca sendo cortada. Um alarme de circuito fechado é mais seguro porque não pode ser anulado cortando o circuito, como acontece em um alarme de circuito aberto.
- **Detecção de movimento:** usa um alarme baseado em movimento ligado a um detector que é acionado por qualquer movimento dentro de uma área, como uma sala (o acionamento é definido pela sensibilidade e pelo alcance do detector). Os sensores nesses detectores são de reflexão de rádio de micro-ondas (semelhante ao radar) ou infravermelho passivo (PIR), que detectam fontes de calor em movimento.
- **Detecção de ruído:** Utiliza um alarme acionado por sons captados por um microfone. A análise moderna baseada em IA e a identificação de tipos específicos de som podem tornar esse tipo de sistema menos propenso a falsos-positivos.
- **Proximidade:** Utiliza etiquetas e leitores de radiofrequência (RFID) para rastrear o movimento de objetos etiquetados dentro de uma área. Isso permite que um sistema de alarme detecte se alguém está tentando remover o equipamento.
- **Coação:** Utiliza um alarme acionado manualmente pela equipe caso estejam sob ameaça. Existem muitas maneiras de implementar esse tipo de alarme, incluindo controles remotos, sensores ou botões ocultos e aparelhos ou smartphones DECT. Algumas fechaduras eletrônicas também podem ser programadas com um código específico para uso sob ameaça diferente do código de acesso comum. Ele abrirá a porta de acesso, mas também alertará o pessoal da segurança de que a porta foi aberta sob coação.

Os alarmes baseados em circuitos são adequados para uso em perímetros e em janelas e portas. Eles conseguem registrar quando uma entrada é aberta sem usar o mecanismo de fechadura corretamente ou quando uma entrada é mantida aberta por mais tempo que um período definido. Os detectores de movimento são úteis para controlar o acesso a espaços que não são normalmente usados. Os alarmes de pânico/sob coação são úteis para funcionários expostos em áreas públicas. Um alarme pode simplesmente soar como um alerta ou ser conectado a um sistema de monitoramento. Muitos alarmes estão diretamente conectados às autoridades locais ou a empresas de segurança terceirizadas. Um alarme silencioso alerta o pessoal da segurança em vez de acionar um alarme sonoro.

Tipos de sensores

[[Sensores]] são fundamentais na implementação de medidas de segurança física, fornecendo capacidades proativas de detecção e alerta contra possíveis violações de segurança. Esses dispositivos podem empregar diversas tecnologias, incluindo sistemas infravermelhos, de pressão, de micro-ondas e ultrassônicos, cada um com suas vantagens e aplicações adequadas.

- Os **sensores infravermelhos** são muito usados em sistemas de detecção de movimento. Eles detectam mudanças nos padrões de calor causadas por objetos em movimento, como um invasor humano. Eles são muito usados em sistemas de segurança residencial e comercial e acionam alarmes ou ativam luzes de segurança ao detectar movimentos.
- Os **sensores de pressão** são normalmente instalados dentro de pisos ou tapetes e são ativados por peso. Eles podem ser usados em áreas de alta segurança para detectar acesso não autorizado ou até mesmo em ambientes de varejo para contar o tráfego de pessoas.
- Os **sensores de micro-ondas** emitem pulsos de micro-ondas e medem a reflexão de um objeto em movimento. Eles muitas vezes são combinados a detectores infravermelhos para oferecer sensores de movimento de tecnologia dupla. É menos provável que esses sensores emitam alarmes falsos, pois os sensores infravermelhos e de micro-ondas devem ser acionados simultaneamente para iniciar o alarme. Eles podem ser úteis para proteger grandes áreas abertas, como estacionamentos ou áreas cercadas.
- Os **sensores ultrassônicos** emitem ondas sonoras em frequências acima do alcance da audição humana e medem o tempo que leva para as ondas retornarem após alcançarem um objeto. Eles são muito usados em sistemas de iluminação automatizados para acender as luzes quando alguém entra em uma sala e desligá-las novamente quando a sala está vazia.



This content is only available on larger screen sizes. Please revisit this page on a larger device.

Você deve ser capaz de explicar a importância do gerenciamento de ativos, dos conceitos de resiliência e dos controles de segurança física no suporte às operações de cibersegurança.

Diretrizes para gerenciamento de ativos e controles de resiliência

A seguir estão alguns conceitos importantes de gestão de ativos:

- Realizar a identificação de ativos.
 - Catalogar todos os ativos, físicos e intangíveis, de uma organização.
 - Incluir informações importantes, como tipo de ativo, localização, valor e propriedade.
- Implementar o gerenciamento do ciclo de vida de ativos.
 - Isso inclui regras para aquisição, manutenção, depreciação e futura aposentadoria ou substituição de um ativo.

- Realizar o rastreamento de ativos.
 - Acompanhar a localização e o status dos ativos, especialmente aqueles que são móveis ou propensos a furtos.
 - Compreender os requisitos de conformidade regulamentar.
 - Certos ativos, como aqueles relacionados à saúde e segurança, proteção de dados ou impacto ambiental, devem ser gerenciados em conformidade com regulamentos específicos para evitar penalidades legais.
 - Realizar o planejamento da recuperação de desastres e continuidade dos negócios.
 - Deve haver planos em vigor para substituir ou restaurar rapidamente ativos críticos em caso de desastres.
 - Descartar ativos de maneira segura.
 - Usar métodos seguros e em conformidade legal para destruir dados.
- Garantir o planejamento de capacidade adequado para pessoas, tecnologias e infraestruturas:
- Implementar estratégias de alta disponibilidade, incluindo:
 - Escalabilidade e elasticidade;
 - Tolerância a falhas e redundância;
 - Clustering;
 - Resiliência do local;
 - Usar avaliações de risco, identificar ativos que têm requisitos de alta disponibilidade e fornecer redundância para atender a esses requisitos:
 - Recursos locais quentes, mornos ou frios para se recuperar de desastres.
 - Usar fontes de alimentação duplas, PDUs, UPSs e geradores para tornar o sistema de alimentação de eletricidade resiliente.
 - Usar o agrupamento de NICs, vários caminhos e balanceamento de carga para tornar as redes resilientes.
 - Usar E/S de múltiplos caminhos e RAID para tornar o armazenamento resiliente.
 - Implementar diversidade nas tecnologias e controles.
 - Realizar testes abrangentes dos recursos de resiliência.

Seguir estas diretrizes para implantar ou atualizar controles de segurança física:

- Se possível, projetar locais como zonas para maximizar os controles de acesso e a vigilância para as áreas a serem mais protegidas usando camuflagem industrial, rede de perímetro, isolamento de dispositivos e cofres, quando aplicável.
- Proteger o perímetro do local e os access points usando cercas, barricadas/bollards e fechaduras (físicas, eletrônicas e biométricas). Se estiver usando cartões inteligentes (smart-cards), use um tipo que seja resistente à clonagem/skimming.
- Monitorar o local usando seguranças, CFTV e drones/UAV e usar iluminação eficaz para maximizar a vigilância.
- Implantar um sistema de alarme (circuito, baseado em movimento, proximidade ou pânico/sob coação) para detectar invasores.
- Usar crachás de identificação para autorizar o acesso.



This content is only available on larger screen sizes. Please revisit this page on a larger device.